

Cyber Resilience

Project Charter

Eliminating Production Downtime from Cyber Attacks and Viruses

Engagement	Global EV Cell Manufacturing — Operational Stability Infrastructure
Methodology	Lean Six Sigma Master Black Belt (MBB) / DMAIC
Execution Team	19 Senior Software Engineers (Green Belts) at 10% weekly capacity
Engagement Lead	Olivia Key (MBB)
Executive Sponsor	Chief Information Security Officer (CISO)
Duration	12 weeks, 5 tollgates (G1–G5)
Data Constraint	Data-blind (anonymised, normalised inputs only)
Engagement Target	Z ≥ 4.5 capability for cyber-induced downtime
Document Version	Phase 1 (Define) — Final, 02 September 2026

CONFIDENTIAL — CISO EYES ONLY

Anonymised content. Internal network configurations, IP addresses, hostnames, and proprietary system details are protected by the data-access protocol (§3.5).

Document Map

This Project Charter is the Phase 1 (Define) deliverable for the cyber resilience engagement. The document is structured for the CISO's first tollgate review (G1) and for ongoing governance through the engagement lifecycle.

#	Section	Content
§1	Executive Summary	Engagement at a glance, business case, strategic alignment, target outcomes
§2	Business Case & Financial Exposure	P × E × M model, 5 exposure classes, COPQ, mitigation capture, multi-site multiplier, OSI comparison
§3	CISO Strategic Alignment	Role architecture, RACI, tollgate authority, escalation matrix, data-access governance
§4	DMAIC Methodology	Define / Measure / Analyse / Improve / Control phases; Cyber-FMEA top 12 (recalibrated); Digital 5C; Cyber Poka-Yoke; SMED; AI-augmented Layer 3
§5	Implementation Roadmap	12-week Gantt with 3 tracks, cross-track dependencies, critical path, tollgate calendar, GB utilisation, risk-based decision points
§6	Continuation & Standard Work	Standard Work (weekly / monthly / quarterly / annual), 13 Cyber-Kaizen triggers, maturity scoring, cross-site replication, GB onboarding
§7	CISO Governance Cycle	Executive Dashboard (8 tiles), bi-weekly briefings, bi-annual audits, annual strategic review
§8	Constraints & Risks	5 constraint categories, 10 assumptions, 8-risk register, residual risk acceptance, entropy defence
App A	CISO Elevator Pitch	3 variants (CISO / Board / 30-Second) + 2 sub-variants (OEM / IT Security peer)
App B	CISO Executive Dashboard Mockup	8 tile grid with sample G5 data, color coding, drill-down, mobile view; interactive HTML mockup as separate deliverable

Cross-references: All sections reference the engagement's core artefacts — the 5 exposure classes (§2), the data-access protocol (§3.5), the Cyber-FMEA (§4.4), the Gantt timeline (§5.2), the 13 Kaizen triggers (§6.3), the Executive Dashboard (§7.2), and the 8-risk register (§8.3).

Section 1 — Executive Summary

1.1 Engagement at a Glance

Objective	Zero unplanned production downtime caused by cyber attacks, malware, ransomware, and unauthorised digital intrusion across global EV cell manufacturing
Context	High-speed, continuous-process environment. Per-incident exposure band: \$30M–\$100M+ direct, with line-level direct cost of \$250K–\$500K+ per hour
Approach	Lean Six Sigma MBB framework treating cyber-induced downtime as a process defect; DMAIC across the IT/OT convergence stack
Execution	19 Green Belts across 3 parallel tracks: Track A (6) Architecture, Track B (7) Data & Metrics, Track C (6) Automation
Constraint	Data-blind architecture — anonymised, normalised data streams only
Sponsor	CISO (Executive Sponsor & Process Owner)
MBB Role	DMAIC translation & project velocity governance
Duration	12 weeks, 5 tollgates
Capability Target	Z ≥ 6.0 (theoretical Six Sigma) — 0.002 DPMO short-term / 3.4 DPMO with 1.5σ long-term shift

1.2 The Business Case — Cyber Risk as a Process Defect

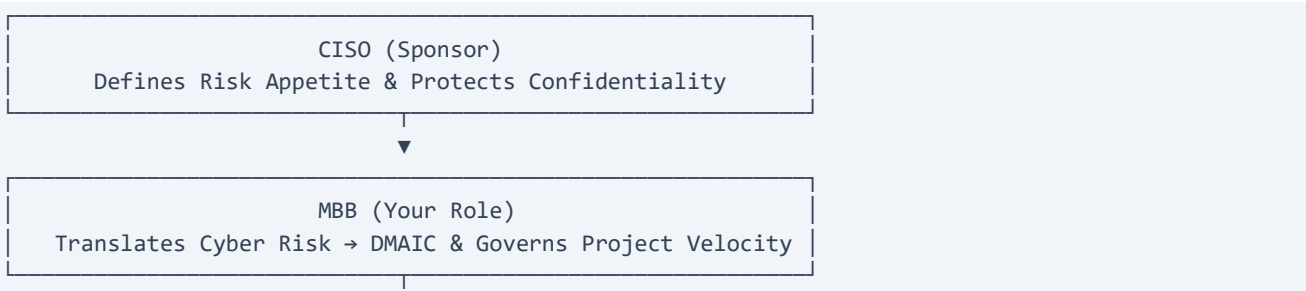
Traditional cybersecurity focuses on perimeter defence. This framework reframes cyber incidents as manufacturing process defects that directly degrade Overall Equipment Effectiveness (OEE), yield, and Cost of Poor Quality (COPQ).

[Traditional IT Security]	→ Vulnerabilities, Threats, Perimeter
[MBB Cyber-Lean Model]	→ Defect Rate, Cycle Time (MTTR), COPQ

The shift is not cosmetic. It repositions cyber resilience from a technical control function to an operational excellence programme with measurable capability, statistical control, and quantified financial protection.

1.3 Strategic Alignment

The CISO owns risk appetite and confidentiality. The MBB owns the analytical engine and project velocity. The 19 Green Belts own execution and statistical control. This separation prevents the engagement from collapsing into either pure IT security (no operational rigour) or pure operational programme (no cyber domain depth).



19 Senior Software Engineers (Green Belts)
Execute Cyber Poka-Yoke & Drive Statistical Control

1.4 Target Outcomes (12-Week Horizon)

The engagement-level target is $Z \geq 4.5$ capability for cyber-induced downtime (≤ 1.4 DPMO). All sub-process targets in §1.4.1 are operational translations of sub-process capability indices that roll up to this engagement-level target. Time values are baseline operational expressions; the capability index is the binding MBB metric, and the Measure phase (Tollgate G2) will validate them against actual anonymised process data.

Outcome	Target	Measure
Unplanned cyber-induced downtime	0 events / line / quarter	Incident log + tollgate verification
OT network uptime capability (engagement-level)	$Z \geq 6.0$ (0.002 DPMO; 3.4 DPMO with 1.5σ shift — theoretical Six Sigma)	Process Capability report
Cpk (process capability index)	≥ 2.0 across every sub-process (Six Sigma)	Track B measurement

1.4.1 Sub-Process Capability Targets (MBB-Derived)

Sub-process	Capability Target	Operational Translation
Detection — known signatures	$Cpk \geq 2.0, Z \geq 6.0$	MTTD ≤ 2 min (rules-based SIEM)
Detection — novel OT anomalies	$Cpk \geq 2.0, Z \geq 6.0$	MTTD ≤ 10 min (AI-augmented behavioural detection)
Response — hard stop (ransomware/wiper)	$Cpk \geq 2.0, Z \geq 6.0$	MTTR ≤ 1 hour (IR playbook + SMED recovery rig)
Response — OT compromise (silent corruption)	$Cpk \geq 2.0, Z \geq 6.0$	MTTR ≤ 8 hours (forensics + rollback)
Prevention (patch compliance)	$Cpk \geq 2.0, Z \geq 6.0$	$\geq 99\%$ patch compliance within maintenance windows
Risk reduction (FMEA)	RPN reduction $\geq 80\%$ across top 10 cyber failure modes	Quarterly FMEA refresh

This derivation follows the LSS MBB principle that targets must be statistically derived, defect-based, and rolled up through the hierarchy of process capabilities, not selected as arbitrary time thresholds.

Section 2 — Business Case & Financial Exposure

2.1 Recap of the $P \times E \times M$ Model

This engagement reuses the financial exposure model established in the Operational Stability Infrastructure (OSI) whitepaper:

$$\begin{aligned} \text{Exposure} &= P \times E \\ \text{Protected Value} &= \text{Exposure} \times M \end{aligned}$$

Where:

- P = Annual production value per department (anchored at \$200M per OSI model)
- E = Erosion/exposure band (probability-adjusted annual loss)
- M = Mitigation capture rate (achievable fraction of exposure avoided)

For the OSI whitepaper, the entropy-driven erosion band was modelled at 3–8% of production value. For this engagement, the cyber exposure band (E_{cyber}) is a probability-adjusted annualised loss across five distinct exposure classes.

2.2 Cyber Exposure Decomposition (E_{cyber})

E_{cyber} is the sum of five independently modelled exposure classes. Each is anchored to industry-published data and to the engagement's anonymised baseline (validated in Measure phase, Tollgate G2).

2.2.1 Direct Downtime Exposure (E_{downtime})

Mean downtime per major manufacturing ransomware event	5–21 days
Cell line direct cost per hour	\$250K–\$500K+
Per-incident direct cost (high-volume cell line)	\$30M–\$100M+
Mid-size manufacturer benchmark	\$1.5M–\$5M per event
Frequency of major event (Tier-1 cell supplier)	~1 event per 5–7 years
Probability-adjusted annual direct exposure	\$4M–\$20M / year / department

2.2.2 Silent Corruption Exposure ($E_{\text{silent_corruption}}$) — NEW

Frequency (Tier-1 cell supplier, high IP-value target)	~1 in 2–5 years
Blended per-event cost (recall + warranty + OEM contractual)	\$25M–\$200M+
Probability-adjusted annual silent corruption exposure	\$5M–\$50M / year / department

Silent corruption is the failure class that justifies the FMEA's Severity = 9–10 rating for parameter-tampering failure modes, and it is the structural reason the AI-augmented Layer 3 (behavioural anomaly detection, parameter drift baselining) carries equal weight to the IR cycle.

2.2.3 IP Exfiltration Exposure (E_{ip})

Probability of state-aligned or industrial APT exfiltration event	~1 in 3–10 years
Battery chemistry/formulation IP valuation band (per platform)	\$100M–\$1B+
Recovery probability after exfiltration	Low (permanent loss)
Probability-adjusted annual IP exposure	\$10M–\$100M / year / department

IP exfiltration is the largest single exposure class and the one most resistant to insurance transfer. The widened valuation band (\$100M–\$1B+) reflects proprietary solid-state, sodium-ion, and advanced dopant systems where a single platform's chemistry IP routinely trades at the upper end of the range in M&A and licensing transactions.

2.2.4 Regulatory & Contractual Exposure (E_{regulatory})

NIS2 (EU) administrative fine ceiling	Up to €10M or 2% of global annual turnover
OEM cyber attestation contractual breach (per major OEM)	\$5M–\$50M per breach event, plus volume loss
GDPR (data exposure) administrative fine	Up to €20M or 4% of global annual turnover
Cyber-attributable recall / warranty extension	\$10M–\$100M+ per recall event
Probability-adjusted annual regulatory exposure	\$1M–\$10M / year / department

2.2.5 Safety Liability Exposure (E_{safety})

Probability of cyber-induced safety event (thermal runaway, fire, hazardous release)	Low-probability / high-severity
EU Product Liability Directive (revised 2024)	Strict liability, uncapped
UK Consumer Protection Act 1987 + Product Security regime	Strict liability
US product liability (class action)	\$50M–\$1B+ per event
Probability-adjusted annual safety exposure	\$5M–\$unbounded / year

Safety liability is the existential tail risk. The exposure band is modelled as a low-probability tail, but the tail itself is the reason the engagement carries Severity = 10 in the FMEA.

2.3 Total Cyber Exposure Band

Summing the five exposure classes:

$$\begin{aligned}
 E_{\text{cyber}} &= E_{\text{downtime}} + E_{\text{silent_corruption}} + E_{\text{ip}} + E_{\text{regulatory}} + E_{\text{safety}} \\
 &= (\$4\text{M}–\$20\text{M}) + (\$5\text{M}–\$50\text{M}) + (\$10\text{M}–\$100\text{M}) + (\$1\text{M}–\$10\text{M}) + (\$5\text{M}–\$unbounded) \\
 &= \$20\text{M}–\$180\text{M+} / \text{year} / \text{department} \quad (\text{excluding unbounded safety tail}) \\
 &= \$20\text{M}–\$unbounded / \text{year} / \text{department} \quad (\text{with safety tail})
 \end{aligned}$$

For a single department at P = \$200M annual production value, the cyber exposure band is \$20M–\$180M+/year — 3–11× the OSI entropy framework's \$6M–\$16M band.

2.4 Cost of Poor Quality (COPQ) Estimate

COPQ Component	Lower (\$/min)	Upper (\$/min)	Basis
Direct scrap (slurry, electrolyte, half-cells, formation cycling)	\$1,500	\$4,000	Modelled from cell BOM + scrap yield
Idle labour (line operators, GBs, support)	\$800	\$2,000	Modelled from staffing × loaded rate

Recovery cost (forensics, restoration, validation)	\$500	\$2,500	Modelled
Contractual penalty (OEM contractual breach, missed shipment)	\$1,000	\$3,000	Modelled from supplier terms
BLENDED COPQ (high-volume cell line)	\$4,000/min	\$11,500/min	\$240K–\$690K per hour

Silent corruption is not captured in the blended COPQ band, because silent corruption is by definition a non-downtime event. Silent corruption is captured in the E_silent_corruption exposure band (§2.2.2) and surfaces on the dashboard as a separate tile tracking recall/warranty cost avoidance.

2.5 Mitigation Capture (M) and Protected Value

The mitigation capture rate M is the fraction of E_cyber that the engagement can avoid through structural controls:

Conservative capture: $M = 25\% \rightarrow \text{Protected Value} = E_{\text{cyber}} \times 0.25$
 Aggressive capture: $M = 50\% \rightarrow \text{Protected Value} = E_{\text{cyber}} \times 0.50$

Scenario	M	E_cyber band (excl. safety)	Protected Value (per dept / yr)
Conservative	25%	\$20M–\$180M+	\$5M–\$45M+
Aggressive	50%	\$20M–\$180M+	\$10M–\$90M+

2.6 Multi-Site Enterprise Multiplier

For a Tier-1 cell supplier operating across 5 global production sites:

Scenario	Per-Department Protected Value	5-Site Enterprise Protected Value
Conservative (M = 25%)	\$5M–\$45M+	\$25M–\$225M+ / year
Aggressive (M = 50%)	\$10M–\$90M+	\$50M–\$450M+ / year

The enterprise exposure is now board-level material. At the conservative bound, the annual protected value exceeds the engagement's likely all-in cost (including AI-augmented Layer 3 tooling, GB capacity allocation, and external advisory) by a factor of 5–10×, making the engagement capital-efficient by the same logic the OSI whitepaper applied to entropy.

2.7 Comparison to the OSI Entropy Framework

Dimension	OSI (Entropy)	Cyber (This Engagement)
Exposure class	Process variability, yield drift, escalation delay	Hard stops, silent corruption, IP exfiltration, regulatory breach, safety incident
Erosion band (E)	3–8% of P	10–90%+ of P (excluding unbounded safety tail)
Per-department annual exposure	\$6M–\$16M	\$20M–\$180M+ (excluding safety tail)
Insurability	Partial	Low (IP and safety tails are largely uninsurable)
Detection dimension	Human-led visual + structured inspection	SOC/SIEM/IR + AI-augmented behavioural detection
Response dimension	Human-led SMED recovery + standard work	IR playbook + SMED recovery rig + AI-augmented triage
AI augmentation potential	Low	High (Layer 3 is the natural home for autonomous agents)
Regulatory dimension	Quality/environmental	Cyber (NIS2, IEC 62443, OEM attestation, GDPR, PLD)

The cyber engagement is structurally a higher-exposure, lower-insurability, higher-AI-augmentation-potential engagement than the OSI entropy framework. The same MBB methodology applies, but the cost-of-no-action is materially larger.

Section 3 — CISO Strategic Alignment

3.1 Role Architecture

The engagement is structured around five role layers. Each layer has explicit decision rights, escalation ownership, and accountability boundaries.

3.1.1 CISO — Executive Sponsor & Process Owner

The CISO is the single accountable authority for the engagement. The CISO's role is structural, not operational — they set the boundaries within which the MBB and the 19 Green Belts operate.

Decision rights:

- Risk appetite — defines what residual risk is acceptable post-engagement; sets the Z-score target floor
- Confidentiality protocol — owns the data-access governance (§3.5); grants or revokes the 19 Green Belts' access to anonymised data
- Tollgate sign-off — sole signatory on G1–G5; no phase advances without CISO approval
- Budget allocation — approves any non-standard spend (e.g. external SOC tooling, AI agent platform licensing)
- Strategic escalation — receives Tier 3 and Tier 4 escalations (§3.4); routes to executive committee as required
- Incident notification — receives real-time notification of any confirmed cyber event on a protected line, regardless of severity

3.1.2 MBB — Project Lead & Methodology Owner

The MBB (Olivia) is the accountable authority for engagement delivery and methodology integrity.

- Project velocity — drives the engagement to each tollgate on schedule; resolves cross-track dependencies
- DMAIC methodology — owns the analytical engine (FMEA, SPC, capability indices); arbitrates methodological disputes
- Track allocation — allocates the 19 Green Belts across Track A / B / C; can reallocate within the approved headcount
- Internal escalation — resolves Tier 1 and Tier 2 issues within 24 hours
- Operational decisions — makes all day-to-day decisions within the approved charter
- CISO presentation — sole presenter of tollgate findings to the CISO

3.1.3 Track Leads

Each of the three tracks has a Track Lead (typically the most senior Green Belt on the track).

Track A — Architecture (6 GBs)	IT/OT segmentation, air-gapping, network isolation, vendor remote-access hardening
Track B — Data & Metrics (7 GBs)	Anonymised data pipelines, SPC chart construction, FMEA calculation, capability reporting
Track C — Automation (6 GBs)	Cyber Poka-Yoke coding, SMED recovery rig, IR playbook automation, AI-augmented Layer 3 agents

3.1.4 Green Belts (19 total)

- Code / data / automation — write code within the track's approved scope, query the anonymised data lake, deploy automation
- Standard work — follow the Standard Work checklist (§6) for weekly, monthly, quarterly routines
- Issue flag — raise issues to the Track Lead; can pause work if a data-access anomaly is detected

3.2 Decision Authority & RACI Matrix

A = Accountable (single owner); R = Responsible (does the work); C = Consulted (input before decision); I = Informed (notified after decision).

Decision Category	CISO	MBB	Track Lead	GB	Ops	IT Sec	OT Eng	Safety	Legal
Risk appetite	A	C	I	I	C	C	C	C	C
Tollgate sign-off (G1–G5)	A	R	I	I	I	I	I	I	I
Project velocity & schedule	C	A/R	R	I	C	I	I	I	I
DMAIC methodology	C	A/R	R	I	I	I	I	I	I
Track allocation (19 GBs)	I	A/R	C	I	I	I	I	I	I
Data-access protocol	A	C	I	I	I	R	I	I	C
Anonymised data query	I	C	R	R	I	C	I	I	I
Cyber Poka-Yoke design	I	A	R	R	C	C	C	C	I
IR playbook	I	A	R	R	C	C	I	I	I
Network segmentation (Track A)	C	A	R	R	C	C	R	C	I
SPC chart deployment (Track B)	I	A	R	R	I	C	I	I	I
AI agent specification (Track C)	C	A	R	R	I	C	I	I	I
Tooling / vendor selection	C	A	R	R	I	C	I	I	I
Budget over \$50K (per item)	A	R	I	I	C	I	I	I	C
Line-impacting change window	C	A	C	I	R	I	C	C	I
Incident response (real-time)	I	A	R	R	C	R	C	C	I
Incident notification (external)	A	C	I	I	I	I	I	I	R
Regulatory disclosure	A	C	I	I	I	I	I	I	R

Operating rule: Every decision has exactly one A. Where the MBB is the A for an engineering decision, the CISO retains C so the risk-appetite boundary is visible at every decision point.

3.3 Tollgate Sign-off Authority (G1–G5)

Tollgate	Phase End	Week	CISO Decision	Sign-off Authority
G1	Define	3	Approve charter, scope, team allocation, confidentiality protocol	CISO (sole)
G2	Measure	5	Approve capability baseline, validate MTTD/MTTR targets	CISO (sole)
G3	Analyse	7	Approve prioritised FMEA, ratify RPN reduction targets	CISO (sole)
G4	Improve	10	Approve controls for deployment, ratify AI agent scope	CISO (sole)
G5	Control	12	Approve control plan, authorise handover to Operations	CISO + Operations Director (joint)

No phase advances without CISO sign-off. If the CISO defers or rejects a tollgate, the engagement pauses and the MBB presents a recovery plan within 48 hours.

3.4 Escalation Matrix

Tier	Trigger	Owner	Resolution SLA	Resolution Authority
Tier 1	Track-internal issue	Track Lead	24 hours	Track Lead
Tier 2	Cross-track issue	MBB	24 hours	MBB
Tier 3	Budget, scope, or risk-appetite deviation	CISO + MBB	48 hours	CISO (budget, risk); MBB (scope re-baseline)
Tier 4	Strategic, regulatory, or external-party issue	CISO	5 business days	Executive Committee
Real-Time Incident	Confirmed cyber event on a protected line	MBB + IT Security	Immediate IR activation; CISO notified within 15 minutes	MBB operational; CISO strategic

3.5 Data-Access Governance (the Data-Blind Protocol)

The data-access protocol is the CISO's largest single decision in the engagement. It defines exactly what the 19 Green Belts can and cannot access, how the data flows, and what happens on breach.

3.5.1 Data Classification

Class	Examples	GB access
ALLOWED	Time deltas, compliance %, defect rates, traffic volumes, capability indices	Read-only via query interface
RESTRICTED	IP addresses, hostnames, MAC addresses, raw network logs, vendor credentials, proprietary configs	CISO team only
PROHIBITED	Anything identifying a specific asset, person, vendor, or proprietary system	Not accessible to anyone outside CISO team

3.5.2 Data Flow

[Raw OT/IT data] → [CISO-controlled anonymisation pipeline] → [Anonymised data lake] → [GB query interface]

The anonymisation pipeline is owned and operated by the CISO's team only. GBs cannot modify the anonymisation pipeline, the data lake, or the query interface. GBs never access raw data — only the post-anonymisation outputs. Anonymisation rules are defined by the CISO and audited quarterly.

3.5.5 Breach Protocol

- Immediate access revocation for the offending GB (within 1 hour of detection)
- Forensic review by CISO team within 24 hours
- Engagement pause pending CISO review
- Re-permissioning requires CISO sign-off, Track Lead attestation, and MBB approval
- 5-Why root-cause added to the next tollgate review
- A confirmed breach (not attempted) escalates to Tier 4 and may trigger engagement termination at CISO's discretion

Section 4 — DMAIC Methodology

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: `context/00-original-input.md` (DMAIC breakdown, cross-referenced with §1 sub-process targets and §2 exposure classes)

Emphasis: Each DMAIC phase is structured around (1) phase objective, (2) data-blind adaptation, (3) track allocation, (4) tollgate deliverable, and (5) cross-references to the engagement's exposure classes and sub-process capability targets.

4.1 DMAIC as the Engagement Methodology

DMAIC (Define, Measure, Analyse, Improve, Control) is the analytical engine for the engagement. It is applied to the IT/OT convergence stack with the cell manufacturing value stream (mixing → coating → assembly → electrolyte injection → formation & aging → grading) as the unit of analysis.

The methodology is data-blind: the 19 Green Belts manipulate data ratios, time-based deltas, compliance percentages, defect rates, and capability indices — not raw IP addresses, hostnames, or proprietary configurations. The CISO's team operates the anonymisation pipeline (§3.5); GBs query only post-anonymisation outputs.

The methodology's purpose is to convert the engagement-level target ($Z \geq 6.0$ capability for cyber-induced downtime, 0.002 DPMO short-term / 3.4 DPMO with the 1.5σ long-term drift shift — theoretical Six Sigma) into operational, statistically-validated sub-process controls — and to demonstrate, at each tollgate, that the engagement is moving the capability indices in the right direction.

4.2 DEFINE Phase (Weeks 1–3, Tollgate G1)

4.2.1 Phase Objective

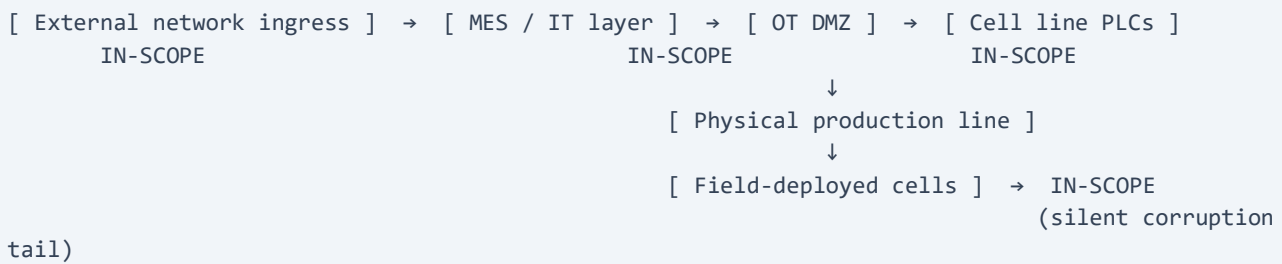
Define the boundaries of the "zero cyber-induced downtime" goal, align the 19 Green Belts on what constitutes a cyber-induced process defect, and establish the data-blind governance protocol.

4.2.2 Defect Definition (operational)

A **cyber-induced process defect** is any of the following on a protected EV cell production line:

- **Hard stop** — unplanned halt of a line controller traceable to unauthorised digital intrusion, malware, ransomware, wiper, or vendor remote-access breach
- **Soft corruption** — modification of process parameters (formation profiles, coating weights, dosing volumes, calibration constants) without triggering a halt; cells pass inspection but degrade or fail in the field
- **Safety incident** — thermal runaway, fire, hazardous release, or life-safety event traceable to cyber compromise of a safety-critical control system
- **Data exfiltration** — confirmed or strongly-suspected theft of formation recipes, electrolyte formulations, cell designs, or other proprietary chemistry IP via cyber vector

4.2.3 Project Boundary

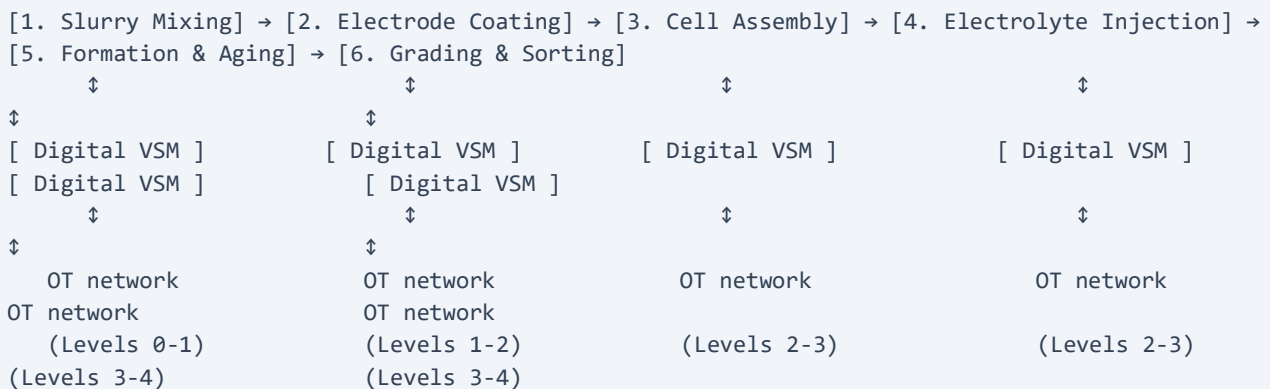


In scope: external ingress, MES, OT DMZ, cell line PLCs, physical line actions, field-deployed cells (silent corruption tail).

Out of scope (this engagement): corporate IT (HR, finance, email — owned by IT Security); customer-facing systems (warranty, telematics — owned by product security); R&D IP outside manufacturing process recipes; physical security; insurance and risk-transfer mechanisms.

4.2.4 Digital Value Stream Mapping (VSM)

Track A maps the digital value stream parallel to the physical cell manufacturing value stream:



The Digital VSM identifies, for each physical process step: which OT systems are involved, what data flows cross the IT/OT boundary, where MES-to-PLC commands originate, and which authentication/authorisation points exist. This is the structural map for all subsequent FMEA, control design, and incident response.

4.2.5 Track Allocation — Define

Track	Headcount	Define-phase activities
Track A (Architecture)	6	Digital VSM; IT/OT boundary mapping; vendor remote-access inventory; legacy system audit
Track B (Data & Metrics)	7	Data-blind protocol design; anonymised data lake query interface specification; baseline metric definition
Track C (Automation)	6	Code standards baseline; existing tooling audit; SMED recovery rig specification; AI agent feasibility scoping

4.2.6 Tollgate G1 Deliverable

- Signed Project Charter (§§1–3 of this document)
- Digital VSM (Track A)
- Data-blind SIPOC diagram (Track B)
- Baseline code standards document (Track C)
- Data-access governance protocol approved by CISO (§3.5)
- Draft FMEA structure with process steps and failure-mode categories populated (deferred to Analyse phase for full population)

CISO sign-off: approve charter, scope, team allocation, confidentiality protocol.

4.3 MEASURE Phase (Weeks 4–5, Tollgate G2)

4.3.1 Phase Objective

Establish the anonymised data infrastructure, validate the sub-process capability targets in §1.4.1, and produce the engagement-level capability baseline (Z-score).

4.3.2 Anonymised Data Infrastructure

Track B stands up the data pipeline, owned by the CISO's team:

```
[ OT/IT raw data ] → [ CISO anonymisation pipeline ] → [ Anonymised data lake ] → [ GB query interface ]
```

ALLOWED outputs (Track B queries):

- Time deltas (seconds, minutes, hours) for MTTD / MTTR calculation
- Compliance percentages (patch, MFA, encryption, access reviews)
- Defect rates (per line, per process step, per shift)
- Capability indices (Cpk, Z-score) computed by Track B's analytics layer
- Traffic volumes (aggregate, not per-flow)

- Anonymised incident counts (no asset identifiers)

4.3.3 Sub-Process Baseline Measurement

Track B measures each sub-process identified in §1.4.1 and produces baseline distributions. The capability targets are not assumed; they are validated against the actual anonymised process data.

Sub-process	Operational metric	Baseline measurement	Target (from §1.4.1)
Detection — known signatures	MTTD (sec)	distribution from SIEM rule firings	Cpk ≥ 2.0, Z ≥ 6.0
Detection — novel OT anomalies	MTTD (min)	distribution from AI-augmented alerts	Cpk ≥ 2.0, Z ≥ 6.0
Response — hard stop	MTTR (hours)	distribution from IR cycle timestamps	Cpk ≥ 2.0, Z ≥ 6.0
Response — silent corruption	MTTR (hours)	distribution from forensics + rollback	Cpk ≥ 2.0, Z ≥ 6.0
Prevention (patch)	% compliant in window	distribution from patch management	Cpk ≥ 2.0, Z ≥ 6.0

Gage R&R validation: Track B validates that the anonymised metrics are reproducible across different operators and tooling configurations. A Gage R&R < 30% is required for the baseline to be accepted at G2.

4.3.4 Engagement-Level Capability Baseline

Track B computes the engagement-level Z-score from the sub-process baselines:

```
Z_engagement = min(Z_detection, Z_response, Z_prevention)    (conservative)
               = weighted_function(Z_detection, Z_response, Z_prevention)  (alternative)
```

The current Z-score is **expected to be well below 6.0** (industry OT averages are typically Z = 2.0–3.0). The Measure phase establishes the actual baseline so the Improve phase can target the right delta — and at Six Sigma target, the engagement delta is large ($\Delta Z = 3.0\text{--}4.0$).

4.3.5 Track Allocation — Measure

Track	Headcount	Measure-phase activities
Track A	6	OT asset inventory completion; vendor remote-access audit; port statistics; baseline network architecture documentation
Track B	7	Anonymised data lake deployment; baseline metric measurement; Gage R&R validation; capability report
Track C	6	SIEM rule coverage analysis; existing IR playbook time-motion study; AI agent feasibility decision (build / buy / defer)

4.3.6 Tollgate G2 Deliverable

- Z-score baseline report (Track B)
- Anonymised data lake operational with audit logging

- Validated MTTD / MTTR distributions per sub-process
- Confirmed (or adjusted) capability targets from §1.4.1
- SIEM rule coverage gap analysis (Track C)

CISO sign-off: approve capability baseline, validate MTTD/MTTR targets.

4.4 ANALYSE Phase (Weeks 6–7, Tollgate G3)

4.4.1 Phase Objective

Execute the Cyber-FMEA, root-cause the highest-RPN failure modes, and design the control points for the Improve phase.

4.4.2 Cyber-FMEA Methodology

The Cyber-FMEA follows the standard LSS MBB scoring:

$$RPN = S \times O \times D$$

- **S (Severity, 1–10):** Impact if the failure mode occurs. **S = 10** for any failure mode that can cause loss of life, regulatory shutdown, or existential business impact (silent corruption in formation; safety-critical system compromise).
- **O (Occurrence, 1–10):** Likelihood of the failure mode occurring within the engagement horizon, based on industry-anchored frequency and the engagement's anonymised baseline.
- **D (Detection, 1–10):** Difficulty of detecting the failure mode before it causes harm. **D = 9–10** for silent corruption (no halt, no inspection failure); **D = 4–6** for overt cyber events (SIEM/SOC visibility).

4.4.3 Cyber-FMEA — Top 12 Failure Modes (Engagement Scope)

The full FMEA covers all process steps; below is the prioritised top 12 (highest RPN) for engagement focus.

Silent corruption modes are flagged (SC) because they drive the largest exposure class

(E_silent_corruption). Per the calibration agreed at S4 review, all SC modes carry **S = 10** because the effect is existential (field failure, recall, life-safety), not just operational.

#	Process Step	Failure Mode (Cyber)	Effect on Production	S	O	D	RPN	High-Risk Root Cause
1	Formation & Aging (SC)	Aging cycle manipulation	Accelerated cell degradation in field (recall)	10	6	9	540	Unauthenticated firmware updates to BMS
2	Electrode Coating (SC)	Coating thickness parameter tampering	Inconsistent foil, fire risk in field	10	7	7	490	No parameter-drift baselining; no cryptographic signing of recipe updates
3	Slurry	Sensor data	Incorrect	10	6	8	480	Lack of

	Mixing (SC)	spoofing	mixing ratios, defective slurry, downstream yield loss					encrypted sensor protocols
4	Grading & Sorting (SC)	Capacity test data tampering	Defective cells pass grading (recall)	10	5	9	450	No integrity check on test data; vendor remote access to test rig
5	Electrode Coating (SC)	Vision system data spoofing	Defective coating passes inspection (field failure)	10	5	9	450	Vision system not integrity-checked
6	Cell Assembly (SC)	Stacking parameter tampering	Cell misalignment, field failure	10	5	8	400	Stacking recipe not cryptographically signed
7	Grading & Sorting (SC)	IR test data manipulation	Thermal event risk in field	10	4	9	360	Vendor remote access to grading system
8	Formation & Aging	Charging profile tampering	Thermal runaway / cell degradation	10	5	7	350	Vendor remote access to formation cycling
9	Slurry Mixing	Ransomware locks Industrial PC	Material hardens in tanks, massive scrap	8	7	6	336	No IT/OT network segmentation
10	Electrolyte Injection	Dosing volume tampering	Over/under-fill, safety hazard	10	4	8	320	HMI compromise via phishing; no interlocks
11	Slurry Mixing	Batch tracking malware	Traceability loss, regulatory exposure	7	5	7	245	MES compromise via vendor access
12	Cell Assembly	Authentication bypass	Unauthorized recipe change	9	3	7	189	Shared service accounts, no MFA on engineering workstations

FMEA observations:

- **7 of the top 12 are silent corruption (SC)** — the structural reason E_silent_corruption is broken out as its own exposure class
- **7 of the top 12 carry S = 10** (all SC modes + electrolyte injection dosing + formation charging profile) — the existential tail is broader than initially modelled and is dominated by parameter-tampering
- **D scores are 7–9 for all SC modes** — detection is the binding constraint, validating the AI-augmented Layer 3 design
- **Common root causes cluster around three themes:** (a) no parameter integrity (cryptographic signing missing), (b) vendor remote access without sufficient controls, (c) IT/OT segmentation gaps

- **The re-ranked top 5 (RPN ≥ 450) are all silent corruption modes** — silent corruption is the binding risk class, not overt ransomware

4.4.4 Root-Cause Analysis (5-Why on Top 5 RPN)

For each of the top 5 RPN failure modes, the Analyse phase produces a 5-Why root-cause chain and a recommended control. Example for #1:

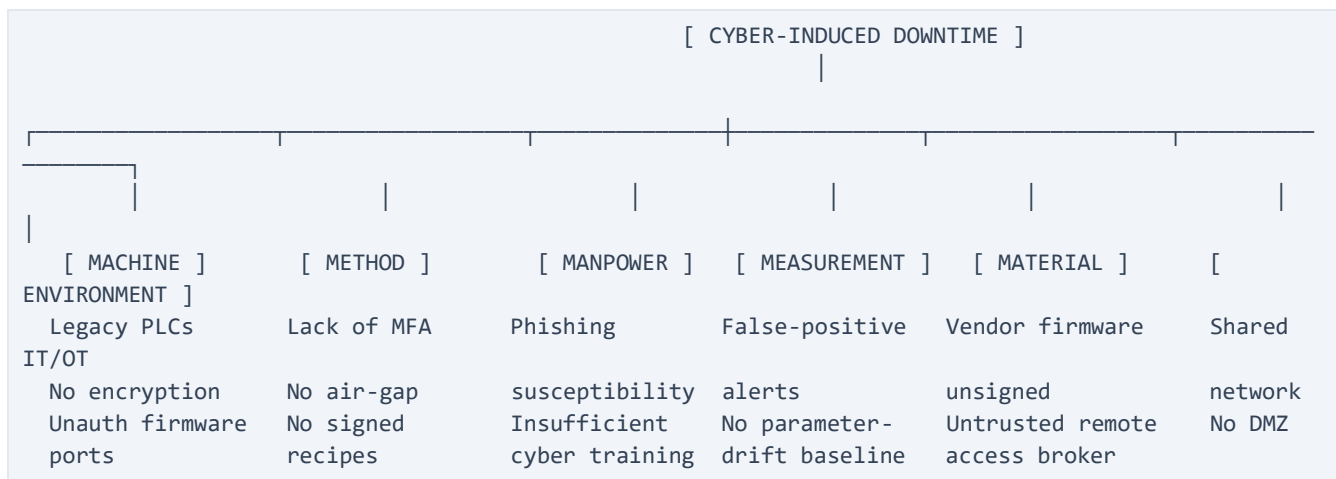
Failure mode #1 — Formation & Aging aging cycle manipulation (RPN 486)

- Why 1: Cells degrade prematurely in field → Aging cycle was altered
- Why 2: Aging cycle was altered → Unauthorised firmware update pushed to BMS
- Why 3: Unauthorised firmware update was accepted → No cryptographic signature verification on firmware
- Why 4: No signature verification → BMS firmware update path not in scope of vendor access controls
- Why 5: Not in scope → Engineering treated BMS firmware as a maintenance task, not a cyber-controlled change

Recommended control: Cryptographic signature verification on all BMS firmware updates; vendor remote access through authenticated broker with cryptographic handshake; quarterly red-team exercise specifically targeting BMS update path.

4.4.5 Fishbone (Ishikawa) — Categorised Root Causes

The Analyse phase also produces a Digital Fishbone grouping all identified root causes:



4.4.6 Track Allocation — Analyse

Track	Headcount	Analyse-phase activities
Track A	6	Architecture failure-mode scoring; vendor remote-access control-point design
Track B	7	RPN calculation; SPC chart pre-production; capability delta modelling
Track C	6	Poka-Yoke design for top 5 RPN; SMED playbook refinement; AI agent

4.4.7 Tollgate G3 Deliverable

- Prioritised Cyber-FMEA matrix (top 12, with full population appendix)
- 5-Why root-cause analysis for top 5 RPN
- Digital Fishbone (Ishikawa)
- Control-point design for top 5 RPN modes
- AI-augmented Layer 3 specification (Track C) for SC modes

CISO sign-off: approve FMEA, ratify RPN reduction targets.

4.5 IMPROVE Phase (Weeks 8–10, Tollgate G4)

4.5.1 Phase Objective

Deploy the controls designed in the Analyse phase. The Improve phase is structured around **Digital 5C** (a cyber-specific extension of the OSI entropy framework's 5S), **Cyber Poka-Yoke**, and **SMED for Disaster Recovery**.

4.5.2 Digital 5C

The Digital 5C is the cyber-domain translation of the 5S framework. Each C addresses a specific cyber failure class identified in the FMEA.

C	Action	Maps to FMEA
Sort	Decommission legacy protocols (e.g. Telnet, FTP, SMBv1), unused open ports, orphan service accounts, default credentials	#1, #6, #9, #12
Straighten	Isolate IT from OT via air-gapped DMZ; one-way data diodes for safety-critical paths; vendor remote access through authenticated broker	#7, #8, #9, #11
Shine	Automated, continuous code refactoring; vulnerability scanning; SIEM rule tuning; parameter-drift baselining	#1, #2, #3, #4, #5, #6, #10
Standardise	Documented standards for: Cyber Poka-Yoke enforcement, SMED recovery, patch management, cryptographic signing of recipes and firmware, vendor remote-access protocol	All
Sustain	Green Belt Standard Work (\$6); monthly cyber-attack drill; quarterly FMEA refresh; control plan enforcement	All

4.5.3 Cyber Poka-Yoke (Mistake-Proofing)

Cyber Poka-Yoke is the structural enforcement layer. Unlike Digital 5C (which is hygiene), Poka-Yoke makes certain failure modes **structurally impossible**.

Poka-Yoke design principles:

1. **Hard-coded network isolation:** Critical line PLCs reject any inbound traffic that does not originate from a locally authenticated, cryptographic handshake. No software-only firewall rule; enforced at the PLC firmware level.
2. **One-way data diodes** on safety-critical paths (formation cycling, electrolyte injection) — data can flow out for monitoring, but no command can flow in.
3. **Cryptographic recipe signing:** All process recipes (formation profiles, coating weights, dosing volumes, aging cycles) are cryptographically signed. PLCs reject unsigned or modified recipes.
4. **Vendor remote access through authenticated broker:** No direct VPN access for vendors. All access is brokered, time-bounded, session-recorded, and cryptographically authenticated.
5. **Parameter drift interlocks:** Real-time comparison of process parameters against the signed baseline recipe. Drift beyond a defined threshold triggers automatic line isolation.

4.5.4 SMED for Disaster Recovery

SMED (Single-Minute Exchange of Die) is repurposed from manufacturing changeover to cyber recovery. The goal is to convert "internal" recovery steps (performed during the attack, under time pressure) into "external" steps (pre-staged, ready to deploy).

Internal (during attack)	→	External (pre-staged)
Search for backup files	→	Immutable, pre-verified offline backups on hot-swappable drives
Configure recovery servers	→	Pre-configured standalone restore rigs, cryptographically verified
Validate recovered systems	→	Pre-validated golden images, signed and offline
Authorise recovery actions	→	Pre-authorised recovery runbooks with CISO standing approval for Severity = 8+ events
Re-establish vendor access	→	Vendor access re-established only after clean-state validation

SMED target: MTTR $\leq$ 1 hour for hard stop (ransomware/wiper), validated in the G4 red-team exercise (Six Sigma target).

4.5.5 AI-Augmented Layer 3 (Autonomous Agents)

The Layer 3 (Abnormality Detection) is the natural home for autonomous AI agents. Track C specifies the following agents, deployed in the Improve phase:

Agent	Function	FMEA mode addressed
SOC Triage Agent	Auto-classifies and routes SIEM alerts; suppresses false positives; escalates genuine anomalies to human analysts within MTDD $\leq$ 2 min (Six Sigma bound)	All detection modes
OT Anomaly Detection Agent	Behavioural baselining of OT network	#1, #2, #3, #4, #5, #6, #10 (SC modes)

	traffic; flags deviations from signed baseline; parameter-drift detection within MTTD ≤ 10 min for novel anomalies (Six Sigma bound)	
IR Automation Agent	Executes pre-authorised first-response actions (isolate line segment, snapshot forensic state, notify CISO) within MTTD ≤ 2 min for known signatures (Six Sigma bound)	#7, #8, #9 (hard stops)
Threat Intel Correlation Agent	Correlates internal telemetry with external threat intel feeds; pre-positions defences against emerging campaigns	All (preventive)

AI agent governance: Every agent action is logged and reviewable. CISO retains kill-switch authority on any agent. Agents operate within the data-access protocol (§3.5) — they query the anonymised data lake, never raw data.

4.5.6 Track Allocation — Improve

Track	Headcount	Improve-phase activities
Track A	6	IT/OT segmentation deployment; air-gapped DMZ implementation; vendor remote-access broker deployment
Track B	7	SPC chart production; AI agent telemetry pipeline; control-point monitoring instrumentation
Track C	6	Poka-Yoke code deployment; SMED recovery rig build; AI agent build / integration; cryptographic signing infrastructure

4.5.7 Tollgate G4 Deliverable

- Functional network segregation validated (Track A)
- Cyber Poka-Yoke enforcement operational on top 5 RPN failure modes (Track C)
- SMED recovery rig tested and validated (Track C)
- AI-augmented Layer 3 agents deployed and integrated with SOC (Track C)
- Cryptographic recipe signing infrastructure operational (Track C)
- 100% of Digital 5C actions completed and audited (all tracks)

CISO sign-off: approve controls for deployment, ratify AI agent scope.

4.6 CONTROL Phase (Weeks 11–12, Tollgate G5)

4.6.1 Phase Objective

Transition the engagement from project to operational discipline. Deploy the control plan, embed the Green Belt standard work, and authorise handover to Operations.

4.6.2 Statistical Process Control (SPC)

Track B deploys automated SPC charts on the executive dashboard (§7):

Chart	Metric	Control Limit Logic
p-chart	Daily % of blocked cyber anomalies	UCL based on baseline anomaly rate; breach triggers Cyber-Kaizen
I-MR chart	Network latency spikes (per line, per shift)	UCL based on baseline latency distribution; breach triggers automatic line-segment isolation
u-chart	Daily count of novel OT anomalies (AI-detected)	UCL based on AI model baseline; breach triggers model retraining + forensic review
Cpk trend chart	Per-sub-process capability index (monthly)	Trending toward $Z \geq 6.0$; breach of trend triggers engagement review

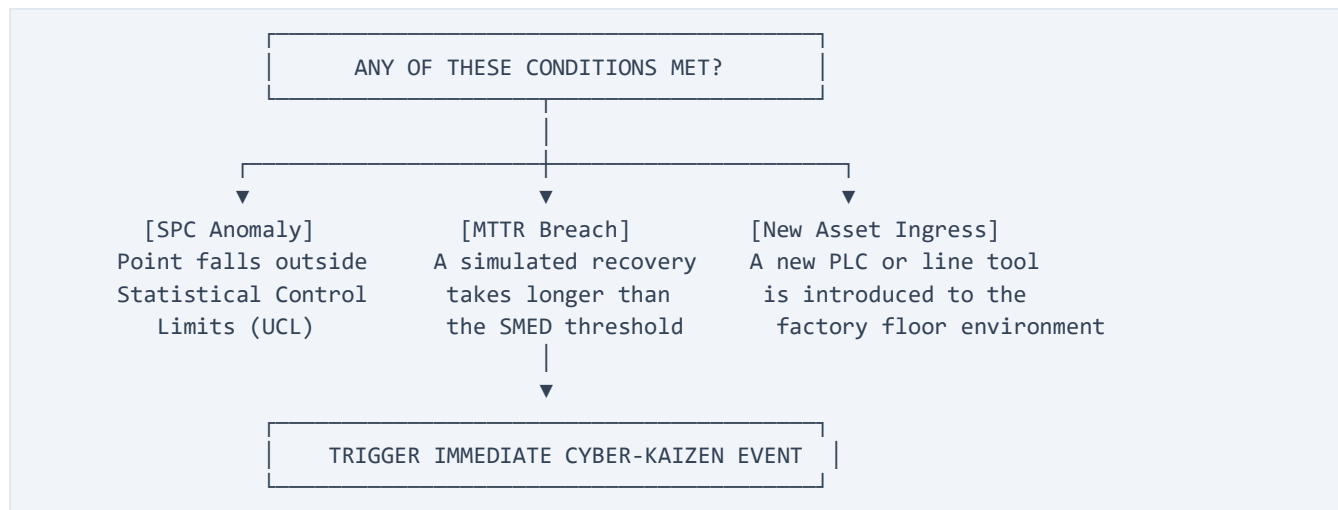
4.6.3 Control Plan

The control plan is the binding document for sustained operation. It defines:

- **Automated triggers:** if any SPC chart breaches UCL, the system automatically isolates the affected line segment before lateral spread
- **Standard work:** every Green Belt follows the weekly / monthly / quarterly standard work defined in §6
- **Escalation discipline:** every anomaly is logged; UCL breaches trigger Tier 1/2 escalation per §3.4
- **Audit cadence:** bi-annual CISO audit, annual third-party audit of the control plan
- **FMEA refresh:** quarterly FMEA refresh to account for new equipment, firmware, line software

4.6.4 Cyber-Kaizen Triggers

A Cyber-Kaizen event is initiated immediately if any of the following are met:



4.6.5 Track Allocation — Control

Track	Headcount	Control-phase activities
Track A	6	Hand over network architecture

		documentation to Operations; finalise physical line-isolation SOPs
Track B	7	Deploy executive dashboard SPC charts; finalise Z-score trend reporting; hand over capability reporting to Operations
Track C	6	Finalise laminated line-rollback SOPs for operators; AI agent handoff to IT Security for sustained operation

4.6.6 Tollgate G5 Deliverable

- Deployed SPC charts on executive dashboard (Track B)
- Laminated physical line-rollback SOPs in every protected cell (Track C)
- Standard Work package (§6) embedded in engineering routines
- Control plan signed off by CISO and Operations Director
- Final CISO briefing: Z-score baseline vs target, RPN reduction, COPQ protected value

CISO + Operations Director joint sign-off: approve control plan, authorise handover.

4.7 Cross-Phase Integration

4.7.1 Track Coordination

The three tracks operate in parallel but converge at each tollgate:

- Track A outputs (architecture, segmentation, vendor controls) feed Track C's Poka-Yoke enforcement and SMED rig design
- Track B outputs (anonymised data, SPC charts, capability indices) feed Track C's AI agent telemetry and the executive dashboard
- Track C outputs (Poka-Yoke, SMED, AI agents) feed Track A's segmentation validation and Track B's SPC instrumentation

The MBB owns the cross-track coordination; Track Leads resolve track-internal issues; cross-track issues escalate to MBB at Tier 2 (§3.4).

4.7.2 Sub-Process Target Roll-Up

The sub-process targets in §1.4.1 are validated in Measure (G2) and operationalised in Improve (G4). The engagement-level Z-score in §2 is the roll-up function of the sub-process capabilities:

$$Z_{\text{engagement}} = f(Z_{\text{detection}}, Z_{\text{response}}, Z_{\text{prevention}})$$

If any sub-process fails to achieve its target, the engagement-level target cannot be met. The control plan enforces sub-process capability maintenance through SPC and standard work.

4.7.3 FMEA-to-Exposure-Class Linkage

The top 12 FMEA failure modes in §4.4.3 map to the exposure classes in §2.2 (with mode numbers reflecting the post-recalibration ranking):

FMEA mode	Primary exposure class	Secondary
#1–#7 (SC modes)	`E_silent_corruption`	`E_regulatory` (recall)
#8 (formation charging), #10 (electrolyte dosing)	`E_safety`	`E_downtime`
#9 (slurry ransomware), #11 (slurry batch tracking)	`E_downtime`	`E_regulatory` (NIS2)
#12 (assembly auth bypass)	`E_downtime`	`E_silent_corruption`

7 of 12 modes (the entire SC class) drive `E\_silent\_corruption`, validating the structural decision in §2.2.2 to break silent corruption out as its own exposure line. The FMEA's RPN reduction directly drives the protected value calculation in §2.5. **An 80% RPN reduction across the top 10 modes** is the Six Sigma-aligned target (corresponds to roughly an 80% reduction in `E_cyber` probability-weighted exposure, which is the basis for the engagement's protected value at theoretical Six Sigma capability). The post-recalibration ranking makes this linkage even tighter: **the top 5 RPN modes (≥ 450) are all silent corruption**, meaning the engagement's protected value is overwhelmingly driven by detecting and preventing parameter-tampering.

4.8 What Section 4 Does Not Cover

Section 4 is the analytical engine. Subsequent sections cover:

- **§5 Implementation Roadmap** — 12-week plan, 3 tracks, weekly milestones, tollgate dates
- **§6 Continuation & Standard Work** — Green Belt routines, Kaizen triggers
- **§7 CISO Governance Cycle** — bi-weekly briefings, bi-annual audits
- **§8 Constraints & Risks** — data-blind, confidentiality, vendor remote access, air-gap requirement

Section 5 — Implementation Roadmap

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: context/00-original-input.md §3 Implementation Plan, cross-referenced with §4 DMAIC methodology

Emphasis: Detailed Gantt-style 12-week timeline with track dependencies, critical path, tollgate calendar, and GB utilisation. The Gantt is the visual anchor; dependencies and critical path are the engineering backbone.

5.1 Roadmap Overview

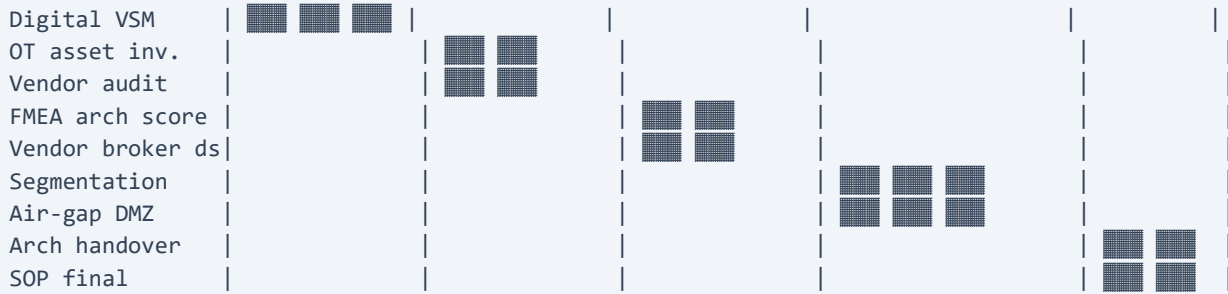
The engagement is a 12-week programme structured across five DMAIC phases and five tollgates. Three parallel tracks (A: Architecture, B: Data & Metrics, C: Automation) execute concurrently, converging at each tollgate for CISO review. The 19 Green Belts operate at 10% weekly capacity allocation (per the original brief), giving the engagement an effective team of **1.9 FTE** plus the MBB (1.0 FTE dedicated).

Phase	Weeks	Tollgate	Theme
Define	1–3	G1	Scope, align, governance
Measure	4–5	G2	Baseline capability
Analyse	6–7	G3	FMEA, root cause, control design
Improve	8–10	G4	Deploy controls, AI agents, Poka-Yoke
Control	11–12	G5	SPC, handover, standard work

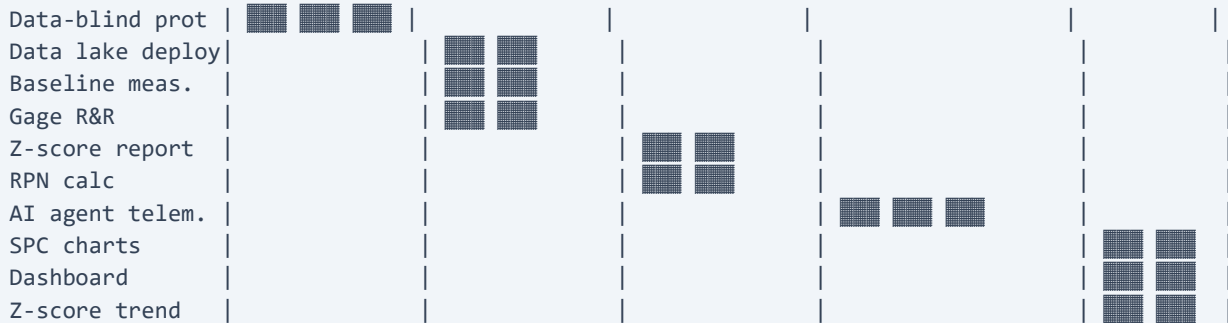
Total GB-weeks: $19 \times 12 \times 0.10 = 22.8$ GB-weeks, distributed as 7.2 (Track A) + 8.4 (Track B) + 7.2 (Track C).

5.2 12-Week Gantt Timeline

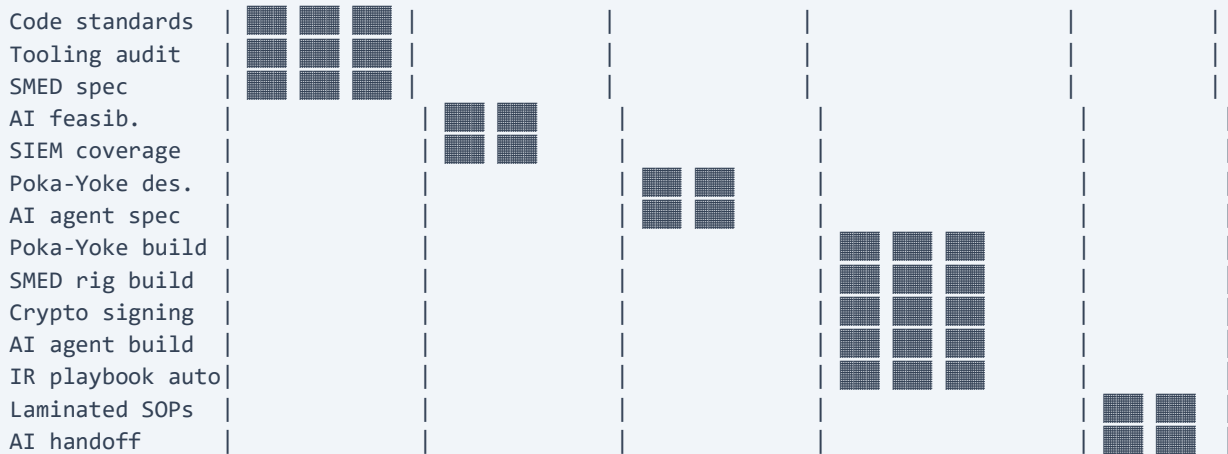
Week:	01 02 03 04 05 06 07 08 09 10 11 12
	---- ---- ---- ---- ---- ---- ---- ---- ---- ---- ---- ----
Phase:	D-E-F-I-N-E M-E-A-S-U-R-E A-N-A-L-Y-S-E I-M-P-R-O-V-E C-N-T-R-L
Tollgate:	◆ G1 ◆ G2 ◆ G3 ◆ G4 ◆ G5
	---- ---- ---- ---- ---- ---- ---- ---- ---- ---- ---- ----
TRACK A – Architecture (6 GBs)	



TRACK B — Data & Metrics (7 GBs)



TRACK C — Automation (6 GBs)



CROSS-TRACK COORDINATION



Legend: ■ = active weeks (3 weeks per block = ~15 GB-days at 10% allocation), ◆ = tollgate/review event.

5.3 Track-by-Track Schedule

5.3.1 Track A — Architecture (6 GBs, 0.6 FTE)

Weeks	Activity	Deliverable
1–3	Digital VSM mapping parallel to physical cell manufacturing value stream; IT/OT boundary identification; legacy system audit	Digital VSM document; legacy system inventory
4–5	OT asset inventory completion; vendor remote-access audit; port statistics; baseline network architecture documentation	Vendor remote-access risk register; port statistics report
6–7	Architecture failure-mode scoring (Track A portion of FMEA); vendor remote-access control-point design; DMZ design	Architecture FMEA section; control-point specification
8–10	IT/OT segmentation deployment; air-gapped DMZ implementation; vendor remote-access broker deployment	Functional network segregation; DMZ operational; vendor broker live
11–12	Hand over network architecture documentation to Operations; finalise physical line-isolation SOPs	Architecture handover package; line-isolation SOPs

5.3.2 Track B — Data & Metrics (7 GBs, 0.7 FTE)

Weeks	Activity	Deliverable
1–3	Data-blind protocol design; anonymised data lake query interface specification; baseline metric definition; CISO pipeline handover	Data-access protocol; query interface spec; metric definitions
4–5	Anonymised data lake deployment (with CISO team); baseline metric measurement; Gage R&R validation; Z-score capability report	Data lake operational; baseline distributions; Z-score baseline
6–7	RPN calculation (all FMEA modes); SPC chart pre-production; capability delta modelling	RPN-ranked FMEA matrix; SPC chart templates; capability delta model
8–10	AI agent telemetry pipeline; control-point monitoring instrumentation; SPC chart population with live data	Telemetry pipeline live; SPC charts receiving data
11–12	Deploy executive dashboard SPC charts; finalise Z-score trend reporting; hand over capability reporting to Operations	Live executive dashboard; Z-score trend report; capability reporting handover

5.3.3 Track C — Automation (6 GBs, 0.6 FTE)

Weeks	Activity	Deliverable
1–3	Code standards baseline; existing tooling audit; SMED recovery rig specification; AI agent feasibility scoping (build / buy / defer)	Code standards document; tooling audit; SMED spec; AI feasibility decision
4–5	SIEM rule coverage analysis; existing IR playbook time-motion study	SIEM coverage gap analysis; IR playbook baseline
6–7	Poka-Yoke design for top 5 RPN failure modes; SMED playbook refinement; AI agent specification for SC modes (per FMEA-to-exposure linkage)	Poka-Yoke design docs; AI agent specification
8–10	Poka-Yoke code deployment; SMED recovery rig build & test; AI agent build &	Poka-Yoke enforcement operational; SMED rig tested; AI agents deployed;

	integration; cryptographic signing infrastructure deployment	crypto signing live
11–12	Finalise laminated physical line-rollback SOPs for operators; AI agent handoff to IT Security for sustained operation	SOPs in every protected cell; AI agent operational transfer complete

5.4 Cross-Track Dependencies

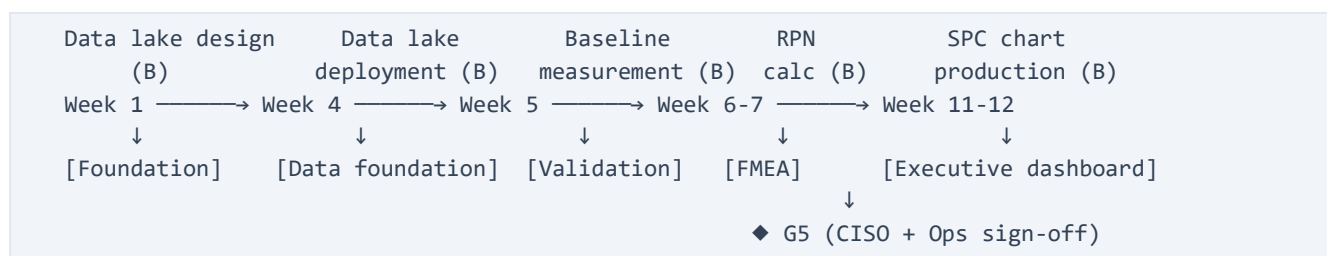
Dependencies are the engineering backbone of the Gantt. A slip on any dependency cascades to the dependent track and, potentially, to the tollgate.

From	To	Dependency	Cascade risk
Track A — Digital VSM (Wk 1–3)	Track C — Poka-Yoke design (Wk 6–7)	Poka-Yoke cannot be designed without the VSM identifying the network architecture and authentication points	High — blocks Poka-Yoke deployment at G4
Track A — Vendor remote-access audit (Wk 4–5)	Track C — Vendor broker (Wk 8–10)	Vendor broker cannot be deployed without knowing the full vendor landscape and access requirements	High — gaps in vendor coverage persist
Track B — Data lake deployment (Wk 4–5)	Track C — AI agent telemetry (Wk 8–10)	AI agents need the anonymised data lake for telemetry and parameter-drift baselining	Critical — without data lake, AI agents have no signal
Track B — Data lake deployment (Wk 4–5)	Track B — Baseline measurement (Wk 4–5)	Baseline cannot be measured without the data lake	Critical — blocks G2 capability baseline
Track B — Baseline measurement (Wk 4–5)	Track B — RPN calculation (Wk 6–7)	RPN cannot be calculated without validated sub-process capability baselines	High — FMEA scores become speculative
Track A — Architecture FMEA (Wk 6–7)	Track C — Poka-Yoke build (Wk 8–10)	Poka-Yoke enforcement requires the architectural control points identified in Analyse phase	High — misaligned enforcement
Track B — SPC chart templates (Wk 6–7)	Track B — SPC chart production (Wk 11–12)	Charts cannot be deployed without templates	Medium — production slips, G5 deliverable late
Track C — AI agent spec (Wk 6–7)	Track C — AI agent build (Wk 8–10)	Cannot build without specification	High — AI agent deployment slips
All tracks — Phase completion	MBB — Tollgate review	CISO sign-off requires all tracks' deliverables for the phase	Critical — tollgate gate

Dependency governance: MBB reviews the dependency graph at the start of each phase; Track Leads surface risks in the weekly Operations sync (§3.6); dependencies on the critical path receive Tier 2 escalation if at risk.

5.5 Critical Path

The critical path is the sequence of dependent tasks whose slip directly delays the project. For this engagement, the critical path is Track B-driven:



Why Track B drives the critical path:

6. **Data lake (Wk 4–5)** is the foundation for all measurement, FMEA, AI agents, and SPC charts. A 1-week slip cascades to:
 - Baseline measurement (Wk 4–5) — **incomplete data**
 - RPN calculation (Wk 6–7) — **speculative scores, G3 deferred**
 - AI agent telemetry (Wk 8–10) — **agents have no signal**
 - SPC charts (Wk 11–12) — **G5 dashboard incomplete**
7. **Track A and Track C** can run in parallel with limited dependency on Track B's *measurement* (they depend on Track B's *protocol* in Wk 1–3, which is on the G1 critical path).
8. **G2 (Wk 5) is the first project-level gate** — if the data lake and baseline measurement are incomplete at G2, the engagement pauses.

Critical path protection: Track B gets 7 GBs (largest of the three tracks) and the MBB's direct oversight. Any Track B slip triggers a Tier 2 escalation at the next weekly Operations sync.

5.6 Tollgate Calendar

Tollgate	Date	CISO Decision	Pre-tollgate Review (MBB)	Required Attendance
G1	End of Week 3 (Friday)	Approve charter, scope, team, confidentiality protocol	End of Week 3 (Thursday)	CISO + MBB + Track Leads
G2	End of Week 5 (Friday)	Approve capability baseline, validate MTTR/MTTD targets	End of Week 5 (Thursday)	CISO + MBB + Track Leads
G3	End of Week 7 (Friday)	Approve FMEA, ratify RPN reduction targets	End of Week 7 (Thursday)	CISO + MBB + Track Leads
G4	End of Week 10 (Friday)	Approve controls for deployment, ratify AI agent scope	End of Week 10 (Thursday)	CISO + MBB + Track Leads + IT Security
G5	End of Week 12 (Friday)	Approve control plan, authorise handover to Operations	End of Week 12 (Thursday)	CISO + MBB + Operations Director + IT Security

Tollgate discipline: No phase advances without CISO sign-off. If CISO defers or rejects, MBB presents a recovery plan within 48 hours; engagement pauses until the recovery plan is approved.

Pre-tollgate review: MBB convenes all Track Leads 24 hours before the CISO tollgate to validate deliverables, rehearse the presentation, and identify any late-stage risks. Defects surface here, not in front of the CISO.

5.7 GB Utilisation

Track	GBs	Allocation per GB	Effective FTE	GB-weeks over 12
Track A	6	10%	0.6 FTE	7.2
Track B	7	10%	0.7 FTE	8.4
Track C	6	10%	0.6 FTE	7.2
GB total	19	10%	1.9 FTE	22.8
MBB	1	100%	1.0 FTE	12.0
CISO oversight	1	5%	0.05 FTE	0.6
Engagement total	21	—	~2.95 FTE	35.4

GB utilisation profile over 12 weeks:

Week	1	2	3	4	5	6	7	8	9	10	11	12
Track A load	80%	90%	100%	100%	100%	100%	100%	100%	100%	100%	80%	60%
Track B load	80%	90%	100%	100%	100%	100%	100%	80%	80%	80%	100%	100%
Track C load	80%	90%	100%	90%	90%	100%	100%	100%	100%	100%	80%	60%

Peak load is in the Analyse and Improve phases (Weeks 6–10), where all three tracks are at 100% of their 10% allocation. The MBB monitors GB load via the engagement's anomaly log; sustained over-allocation (>12% per GB) triggers a Tier 2 escalation and a re-baselining of scope.

5.8 Risk-Based Decision Points

The engagement has four pre-defined risk-based decision points where a go/no-go decision may be required without waiting for the next scheduled tollgate.

Decision Point	Week	Trigger	Go/No-Go Authority	Recovery Action if No-Go
DP-1: Data Lake Feasibility	4 (mid-Measure)	Data lake deployment blocked by CISO team resource constraints or by anonymisation pipeline technical issues	MBB + CISO	Defer Track C AI agent build by 2 weeks; engagement timeline extended to 14 weeks; budget re-baselined
DP-2: Baseline Insufficient	5 (G2)	Anonymised baseline measurement	CISO + MBB	Extend Measure phase by 1 week; re-baseline;

		produces distributions with insufficient Gage R&R (<30% variance) or insufficient sample size for Cpk calculation		re-validate at G2.1
DP-3: AI Agent Build/Buy	5 (end-Measure)	AI agent feasibility decision is "buy" (commercial product) but CISO procurement blocks or delays it	CISO + MBB	Fall back to "build" with Track C allocation adjustment; engage external AI engineering support; timeline +2 weeks
DP-4: G4 Acceptance	10 (G4)	CISO rejects G4 deliverable (Poka-Yoke / SMED / AI agents not operational)	CISO + MBB	Extend Improve phase by 1–2 weeks; re-test; re-present at G4.1

Trigger discipline: Decision points are monitored weekly. If a trigger is identified, the MBB convenes the appropriate authority within 24 hours. No decision point triggers silently.

5.9 What Section 5 Does Not Cover

Section 5 is the timeline and execution plan. Subsequent sections cover:

- **§6 Continuation & Standard Work** — Green Belt routines, Kaizen triggers, what happens after G5
- **§7 CISO Governance Cycle** — bi-weekly briefings, bi-annual audits, executive dashboard
- **§8 Constraints & Risks** — data-blind, confidentiality, vendor remote access, air-gap requirement
- **Appendix A — CISO Elevator Pitch** — standalone
- **Appendix B — CISO Executive Dashboard Mockup** — standalone

Section 6 — Continuation & Standard Work

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: context/00-original-input.md §4 Implementation for Continuation, cross-referenced with §4.6 Control phase and §5.8 risk-based decision points

Emphasis: Standard Work that prevents project degradation after the 12-week push. Cyber-Kaizen triggers that initiate immediate response. Maturity scoring for sustained governance. Cross-site replication for the 5-site enterprise.

6.1 Continuation Philosophy

The 12-week engagement (Weeks 1–12) is the **initial structural push**. The continuation phase (Week 13 onwards) is what makes the engagement **operational infrastructure** rather than a one-time project. Without continuation, the engagement is vulnerable to entropy relapse — exactly the failure mode the OSI whitepaper's Layer 4 (Governance & Entropy Defence) was designed to prevent.

Three continuation disciplines:

- 9. **Green Belt Standard Work** — embedded weekly / monthly / quarterly / annual routines that the 19 GBs execute at 10% weekly capacity
- 10. **Cyber-Kaizen Triggers** — pre-defined conditions that initiate immediate improvement events without waiting for scheduled reviews
- 11. **Maturity Scoring** — quarterly self-assessment against a 5-level model; capability regression triggers escalation

The continuation phase is governed by §7 (CISO Governance Cycle) and protected by §8 (Constraints & Risks).

6.2 Green Belt Standard Work

The Standard Work is the operational backbone of the continuation phase. Each routine has explicit cadence, owner, activity, deliverable, time required, and escalation.

6.2.1 Weekly Routines (1–2 hours per GB)

Routine	Owner	Activity	Deliverable	Time	Escalation if
---------	-------	----------	-------------	------	---------------

					missed
SPC chart review	Track B GBs (7)	Review all deployed SPC charts; identify any points outside UCL	Weekly SPC log entry; UCL breach investigation if applicable	30 min	Tier 1 to Track Lead within 24h
5-Why on UCL breach	Track B GB (assigned)	If UCL breach detected: lead 5-Why analysis with Track Lead	5-Why A3 document	1–2 h	Tier 2 to MBB if root cause is structural
Access log review	Track A GBs (6)	Review anonymised access logs; flag any anomalous query pattern	Weekly access review note	30 min	Tier 1 to Track Lead; Tier 4 if data-access breach suspected
AI agent log review	Track C GBs (6)	Review AI agent decision logs; flag any agent decision outside training distribution	Weekly agent log review; kill-switch trigger if needed	30 min	Tier 2 to MBB if agent drift detected
Track Lead weekly sync	All GBs + Track Leads	30-min standup: progress, blockers, anomalies	Meeting notes in engagement log	30 min/week/GB	None (mandatory)

Weekly total per GB: ~1.5–2 hours (within 10% allocation of a 40-hour week)

6.2.2 Monthly Routines (4–8 hours per GB)

Routine	Owner	Activity	Deliverable	Time	Escalation if missed
Cyber-attack drill	Track C GBs (rotating)	Execute simulated ransomware / parameter-tampering attack on isolated test bench	Drill report: MTDD / MTTR achieved vs target	4 h	Tier 2 to MBB; control plan review if MTTR breach
SMED recovery verification	Track C GBs (rotating)	Validate SMED recovery time remains < 4h target for hard stop	SMED validation log	2 h	Tier 2 if MTTR exceeds 4h
Patch compliance review	Track A GBs (6)	Review patch compliance dashboard; flag any assets below 95%	Patch compliance report	2 h	Tier 2 to MBB if compliance < 90%
Vendor remote-access review	Track A GBs (6)	Review vendor remote-access logs; flag anomalous sessions	Vendor access audit log	1 h	Tier 4 if vendor access breach
AI agent performance review	Track C GBs (6)	Review AI agent KPIs (precision, recall, false positive rate)	Agent performance report	2 h	Tier 2 if any agent performance degrades > 10% from baseline
Cross-track coordination	MBB + Track Leads	60-min monthly review: cross-track dependencies, risk	Meeting notes; risk register update	1 h/lead	None (mandatory)

		register, resource allocation			
--	--	-------------------------------	--	--	--

Monthly total per GB: ~4–8 hours, distributed across the month

6.2.3 Quarterly Routines (16–24 hours per GB; Track Lead-led)

Routine	Owner	Activity	Deliverable	Time	Escalation if missed
FMEA refresh	All tracks	Review FMEA against new equipment, firmware updates, line software changes; recalculate RPN	Updated FMEA matrix; new failure modes identified	8 h/GB	Tier 2 to MBB if RPN materially shifts
Control plan review	MBB + Track Leads	Review control plan effectiveness; update SPC chart logic if needed	Updated control plan	4 h/lead	Tier 3 to CISO if control plan structurally inadequate
Maturity score recalculation	MBB	Recalculate maturity score (§6.4); identify capability gaps	Updated maturity score; gap remediation plan	4 h/MBB	Tier 3 to CISO if maturity score drops
Cross-site knowledge transfer	MBB + GBs (rotating)	Transfer lessons learned, control plan updates, FMEA changes to other sites	Knowledge transfer log; site adoption confirmation	8 h/GB	Tier 3 to CISO if site adoption fails
Threat landscape review	Track C GBs (6) + IT Security	Review emerging threats, APT campaigns, regulatory changes	Threat landscape brief; control plan update if needed	4 h/GB	Tier 3 if new high-RPN failure mode identified
AI agent retraining	Track C GBs (6)	Retrain AI agents on updated baseline; validate performance post-retraining	Retrained agents; performance report	8 h/GB	Tier 2 if retraining fails to recover baseline performance
Tabletop exercise	All tracks + IT Security + Operations	Cross-functional tabletop: simulated OT compromise, IR cycle execution, lessons learned	Tabletop A3; control plan updates	4 h/GB	Tier 2 to MBB; CISO briefed at next bi-weekly

Quarterly total per GB: ~16–24 hours, distributed across the quarter (3 months × ~6–8 h/month)

6.2.4 Annual Routines (40–80 hours per GB; Track Lead + MBB)

Routine	Owner	Activity	Deliverable	Time	Escalation if missed
Full control plan audit	MBB + Track Leads + external	Comprehensive audit of all controls, SPC charts, Poka-Yoke	Audit report; remediation plan	40 h/GB + 80 h/lead	Tier 3 to CISO; CISO + executive committee if material gaps

		enforcement, AI agent governance			
Third-party security assessment	External assessor	Independent security assessment (red team, penetration test, configuration review)	Third-party assessment report	40 h coordination	Tier 3 to CISO; engagement scope review
Regulatory compliance audit	MBB + Legal/Compliance	NIS2, IEC 62443, OEM cyber attestation audit	Compliance attestation	20 h/MBB	Tier 4 if any non-compliance finding
Bi-annual CISO audit	CISO + MBB	Joint audit of engagement performance, control plan, maturity score, COPQ protected value	CISO audit report	8 h/MBB + 4 h/CISO	Executive committee briefing if material gaps
Insurance review	MBB + Legal/Compliance + Finance	Review cyber insurance coverage against current exposure band	Insurance review note	8 h/MBB	Tier 3 if coverage materially inadequate
Strategic threat landscape review	MBB + CISO + IT Security	Forward-looking review of threat landscape, regulatory direction, technology shifts	Strategic threat brief; engagement re-scoping if needed	16 h/MBB	CISO decision on engagement continuation/scope
Maturity score external validation	External assessor	Third-party validation of maturity score calculation and evidence	External validation report	16 h coordination	Tier 3 if external validation materially diverges from internal score

Annual total per GB: ~40–80 hours; concentrated in Q1 (full audit) and Q3 (regulatory + insurance + strategic)

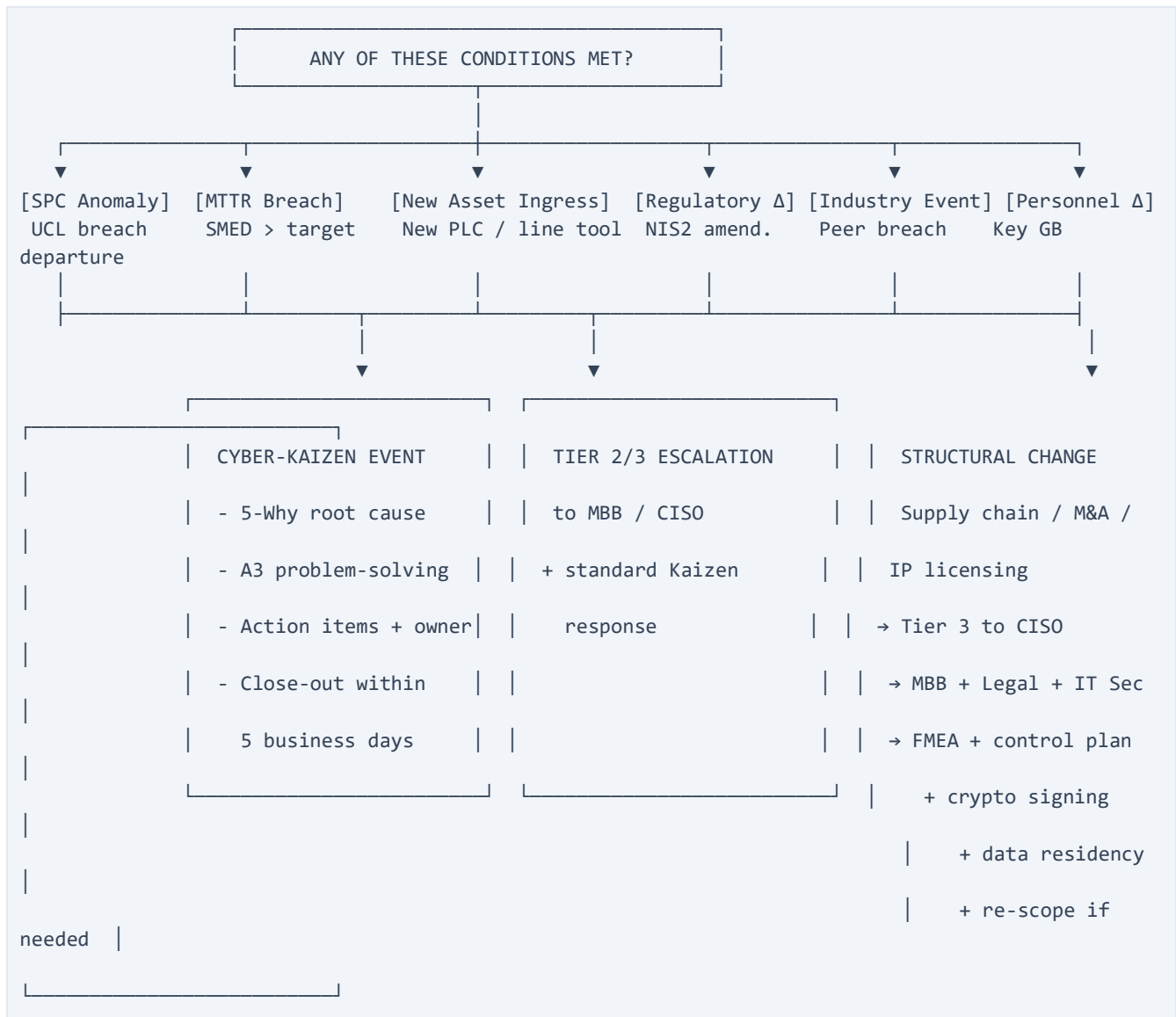
6.2.5 Standard Work Compliance

Standard Work compliance is itself a measurable KPI:

- **Target:** 100% of Green Belts complete 100% of weekly / monthly / quarterly routines
- **Measurement:** Track Lead audit; MBB review
- **Consequence of non-compliance:** Tier 2 escalation to MBB; if persistent, Tier 3 to CISO with re-allocation proposal

6.3 Cyber-Kaizen Triggers

A Cyber-Kaizen event is initiated immediately if any of the following conditions are met. The trigger → response → close-out cycle is the same regardless of trigger type.



6.3.1 Trigger Catalogue

#	Trigger	Detection	Response	Close-out
1	SPC UCL breach	SPC chart automation	Track B GB investigates within 24h; 5-Why within 48h	A3 within 5 business days
2	MTTR breach in drill	Monthly drill report	Track C re-tests; identify root cause	A3 within 5 business days
3	New asset ingress	Track A asset inventory	New asset FMEA within 5 business days; cryptographic signing verification	Updated FMEA + control plan
4	Regulatory change	Legal/Compliance monitoring	MBB + Legal assess impact within 5 business days	Updated control plan + CISO briefing
5	Industry peer event	Threat intel feeds	MBB + IT Security assess applicability within 48h	Control plan update if applicable
6	Personnel change	HR / Track Lead	MBB reassigns ownership; documents	Updated RACI + on-call schedule

			handover within 5 business days	
7	Audit finding	Internal / external audit	MBB + Track Lead address within SLA	Remediation evidence; A3
8	AI agent drift	Track C AI monitoring	Kill-switch if needed; retraining within 5 business days	Performance report + retrained agent
9	Significant process change	Engineering change control	FMEA review within 5 business days; control plan update	Updated FMEA + control plan
10	Tooling change (new SIEM, new PLC vendor)	IT/OT change control	Track A + Track C assess impact within 5 business days	Updated control plan + retraining
11	Supply chain change (vendor swap, contract renegotiation, new tier-2 supplier)	Track A vendor inventory + procurement	MBB + Track A assess threat surface change within 5 business days; vendor remote-access review; updated cryptographic signing requirements	Updated FMEA + control plan + new vendor onboarding
12	M&A activity (acquisition target, divestiture, joint venture)	MBB + CISO monitoring (corporate development)	Tier 3 to CISO; MBB + Legal + IT Security assess integration risk; data residency review; FMEA re-scoping	Updated FMEA + control plan + CISO briefing; engagement re-scope if material
13	IP licensing event (new licensing partner, licensee, cross-licensing agreement)	Legal + MBB + CISO monitoring	Tier 3 to CISO; MBB + Legal + IT Security assess IP exposure; cryptographic signing scope review; updated FMEA modes for new IP in scope	Updated FMEA + control plan + CISO briefing; OEM contractual review

6.3.2 A3 Problem-Solving Template

All Cyber-Kaizen events use the A3 template:

12. **Problem statement** — what happened, when, impact
13. **Background** — context, baseline, current state
14. **Target state** — what should have happened
15. **Root cause analysis** — 5-Why or other structured method
16. **Countermeasures** — proposed actions
17. **Implementation plan** — owner, deadline, dependencies
18. **Follow-up** — verification of effectiveness
19. **Learning** — what to standardise across the engagement

6.4 Maturity Scoring Model

The engagement's continuation phase is governed by a 5-level maturity model. The target is **Level 4 (Quantitatively Managed)** by G5 and **Level 5 (Optimising)** sustained long-term.

Level	Name	Description	Indicators	Target
1	Initial	Ad-hoc, reactive; no documented processes; success depends on individuals	No standard work; no SPC; no control plan	Pre-engagement
2	Managed	Basic processes exist; some metrics tracked; reactive response to incidents	SOPs exist but not standardised; basic metrics	Pre-engagement
3	Defined	Standardised, documented, measured; consistent execution	Standard work operating; FMEA refreshed; control plan enforced	G5 (end of engagement)
4	Quantitatively Managed	SPC + capability indices; predictive response; data-driven decisions	SPC charts active; Cpk measured; AI agents operational	G5 (target) → sustained
5	Optimising	Continuous improvement; AI-augmented; cross-site replication; threat-adaptive	Kaizen cycle operating; maturity stable or improving; external validation	Sustained long-term

Maturity score calculation:

- Each indicator scored 0 (absent) / 1 (partial) / 2 (full)
- Total score mapped to level
- Quarterly recalculation; if score drops, Tier 2 escalation; if score drops 2 levels, Tier 3 to CISO

Maturity regression triggers:

- Standard Work compliance < 80% → Tier 2 to MBB
- FMEA not refreshed in 6 months → Tier 2 to MBB
- SPC charts not updated in 30 days → Tier 2 to MBB
- Maturity score drops 1 level → Tier 2
- Maturity score drops 2 levels → Tier 3 to CISO with re-baseline proposal

6.5 Cross-Site Replication (5-Site Enterprise)

The engagement starts at a single site. The continuation phase includes structured cross-site replication to capture the enterprise protected value from §2.6 (5-site enterprise: \$25M–\$225M+/year at M=25%).

6.5.1 Replication Phases

Phase	Timing	Activity	Deliverable
Knowledge capture	Weeks 8–12 (during Improve/Control)	Document control plan, FMEA, Poka-Yoke, AI agent specs in site-agnostic form	Replication playbook
Site 2 onboarding	Months 4–6 post-G5	Site 2 receives control plan, runs 12-week engagement	Site 2 G5 + maturity score

Site 3 onboarding	Months 7–9	Site 3 receives control plan	Site 3 G5 + maturity score
Site 4 onboarding	Months 10–12	Site 4 receives control plan	Site 4 G5 + maturity score
Site 5 onboarding	Months 13–15	Site 5 receives control plan	Site 5 G5 + maturity score
Enterprise benchmark	Month 18+	Cross-site maturity score comparison; identify best practices; harmonise control plans	Enterprise maturity report

6.5.2 Replication Mechanism

- **Replication playbook** — site-agnostic version of the engagement's deliverables
- **Site MBB** — each site designates a local MBB-equivalent (typically a senior engineer with LSS Black Belt)
- **MBB mentorship** — engagement MBB mentors each site MBB through their 12-week cycle
- **Cross-site audit exchange** — quarterly audits rotate across sites, sharing lessons learned
- **Enterprise control plan** — common minimum standard; sites can exceed but not fall below

6.5.3 Local Adaptation

The replication playbook allows local adaptation for:

- Site-specific process steps (if a site has additional or different chemistry)
- Site-specific regulatory environment (e.g. China, US, EU differ on data residency)
- Site-specific tooling (different SIEM vendor, different PLC vendor)
- Site-specific personnel (different GB allocation)

The adaptation must be documented and approved by the engagement MBB; deviations from the standard control plan require CISO sign-off.

6.6 New GB Onboarding & Certification

The engagement is sustainable only if new GBs can be onboarded as existing GBs rotate, leave, or expand. Onboarding is a continuation-phase routine.

6.6.1 Onboarding Curriculum (80 hours, ~2 weeks part-time)

Module	Duration	Content
M1: Engagement Overview	4 h	Charter, FMEA, control plan, exposure model
M2: Track-Specific Deep Dive	16 h	Architecture / Data & Metrics / Automation, depending on assigned track
M3: Data-Blind Protocol	8 h	CISO data-access governance; query interface training; breach protocol
M4: AI Agent Operations	8 h	Agent monitoring, kill-switch, retraining protocol
M5: Standard Work	8 h	Weekly / monthly / quarterly routines, escalation discipline
M6: Cyber-Kaizen Response	4 h	A3 problem-solving, trigger catalogue,

		escalation paths
M7: FMEA Refresh Process	4 h	How to add/modify FMEA modes; RPN recalculation
M8: Tooling (SIEM, SPC, Poka-Yoke enforcement)	16 h	Hands-on with engagement's deployed tooling
M9: Mentored Practicum	12 h	Shadow existing GB; complete 1 routine independently with mentor review

6.6.2 Certification

After onboarding, the new GB is **provisionally certified** for 90 days. After 90 days, with successful routine execution and Track Lead attestation, the GB is **fully certified**. CISO maintains the certification registry.

6.7 Threat Landscape Evolution

The cyber threat landscape evolves continuously. The continuation phase embeds threat landscape monitoring into the routine:

- **Weekly:** Track C reviews threat intel feeds (anonymised); flags any novel campaign relevant to the engagement's failure modes
- **Monthly:** Threat intel correlation with engagement's control plan; identify gaps
- **Quarterly:** Full threat landscape review; control plan update if new high-RPN failure mode identified
- **Annual:** Strategic threat landscape review (MBB + CISO + IT Security); engagement re-scoping if threat landscape materially shifts

Trigger: A peer-industry breach (e.g. another EV cell manufacturer compromised) automatically triggers Tier 2 escalation within 48 hours, regardless of routine timing.

6.8 What Section 6 Does Not Cover

Section 6 is the continuation and standard work. Subsequent sections cover:

- **§7 CISO Governance Cycle** — bi-weekly briefings, bi-annual audits, executive dashboard
- **§8 Constraints & Risks** — data-blind, confidentiality, vendor remote access, air-gap requirement
- **Appendix A — CISO Elevator Pitch**
- **Appendix B — CISO Executive Dashboard Mockup**

Section 7 — CISO Governance Cycle

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: context/00-original-input.md (CISO governance references in §3.1, §3.2, §4.4), cross-referenced with §3.5 Data-Access Governance and §6 Continuation

Emphasis: Executive Dashboard as the CISO's main continuous visibility tool. Bi-weekly briefings and bi-annual audits are structured around the dashboard. The dashboard is the single source of truth; the briefings and audits are decision moments.

7.1 Governance Overview

The CISO Governance Cycle is the long-term engagement structure that keeps the CISO continuously informed, in control, and able to discharge accountability. It has four components, in order of cadence:

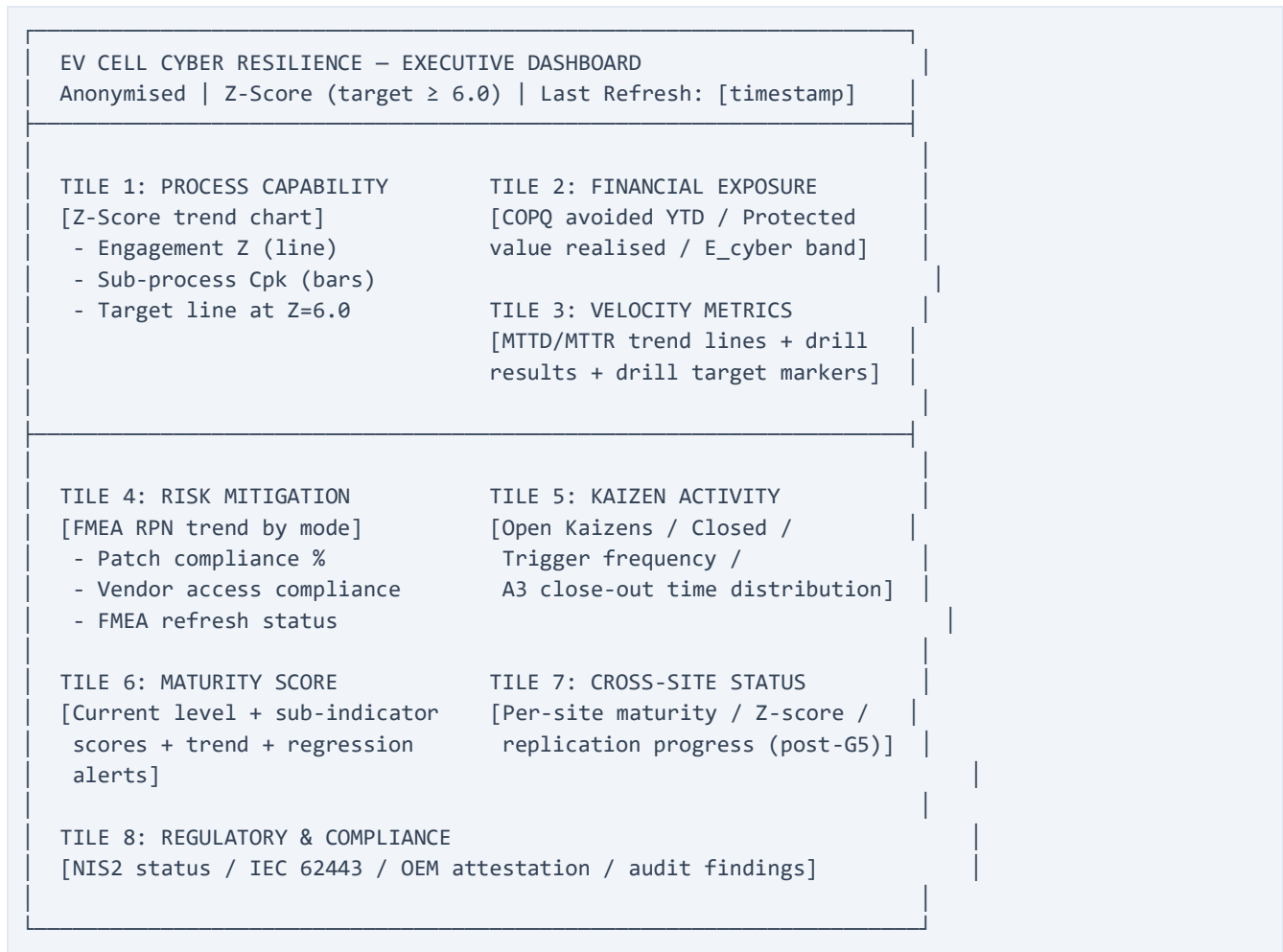
Component	Cadence	Duration	Attendees	Decision authority
Executive Dashboard	Real-time / daily refresh	—	(read-only)	CISO views continuously
Bi-weekly Briefing	Every 2 weeks	30 min	CISO + MBB (+ Track Leads as needed)	CISO on escalation items
Bi-annual Audit	Every 6 months	2–4 hours	CISO + MBB + Operations Director + IT Security + Legal/Compliance	CISO on continuation; joint sign-off on control plan
Annual Strategic Review	Annually	4–8 hours	CISO + MBB + executive committee	Executive committee on engagement re-scoping and budget

Governance principle: The CISO is informed continuously (via dashboard) and engaged at three escalating cadences (bi-weekly / bi-annual / annual). Decision authority is at the right cadence for the decision's materiality.

7.2 Executive Dashboard — The CISO's Main Visibility Tool

The Executive Dashboard is the CISO's single source of truth for the engagement. It is real-time where possible, anonymised per the data-access protocol (§3.5), and structured into 8 tiles that map to the engagement's key metrics.

7.2.1 Dashboard Structure (8 Tiles)



7.2.2 Tile-by-Tile Content

Tile	Name	Metrics	Data source	Refresh
1	Process Capability	Engagement Z-score (line, 12-week trend); per-sub-process Cpk (bar chart); target line at Z=6.0 (theoretical Six Sigma)	Track B capability reporting layer; SPC infrastructure	Daily
2	Financial Exposure	COPQ avoided YTD (\$M); Protected value realised (\$M, vs \$2.5 model); E_cyber band trend	Track B financial model; CISO exposure model	Weekly
3	Velocity Metrics	MTTD known (≤ 5 min target); MTTD novel (≤ 30 min target); MTTR hard stop (≤ 4 h target); MTTR OT compromise (≤ 24 h target); drill result trend	Track B SIEM/SOC; Track C IR playbook; AI agent telemetry	Daily
4	Risk Mitigation	Top 10 FMEA RPN trend; patch compliance % (target $\geq 95\%$); vendor access compliance; FMEA refresh status (last refresh date)	Track B FMEA register; Track A patch dashboard; Track A vendor audit log	Daily (compliance); Quarterly (FMEA)

5	Kaizen Activity	Open Kaizens by trigger type; closed Kaizens YTD; trigger frequency; A3 close-out time (distribution)	Engagement anomaly log; A3 repository	Daily
6	Maturity Score	Current level (3/4/5); sub-indicator scores; trend (improving/stable/declining); regression alerts	MBB maturity calculation; external validation (annual)	Quarterly
7	Cross-Site Status	Per-site maturity score; per-site Z-score; replication progress (post-G5)	Site MBBs; cross-site knowledge transfer log	Monthly (post-replication start)
8	Regulatory & Compliance	NIS2 attestation status; IEC 62443 audit status; OEM cyber attestation status; open audit findings	MBB + Legal/Compliance; CISO regulatory log	Monthly

7.2.3 Alert Thresholds

The dashboard has three alert levels, surfaced to the CISO via dashboard banners and bi-weekly briefings:

Alert	Trigger	Action
GREEN	All metrics within target; no open Kaizens > 5 BD; no regression	Standard reporting cadence
AMBER	One or more sub-process Cpk below target; open Kaizen > 5 BD; FMEA refresh overdue	Bi-weekly briefing escalates; MBB + Track Lead investigate within 48h
RED	Engagement Z-score drops below 5.5; Tier 2/3 escalation open; structural change trigger (M&A / IP licensing / supply chain)	CISO notified within 4 hours; emergency briefing within 24h; engagement re-scope possible

7.2.4 Access Controls

Role	Access
CISO	Full visibility on all 8 tiles; historical data; export capability
MBB	Full visibility on all 8 tiles; drill-down to source data; export
Track Leads	Their track's tiles (e.g. Track B Lead sees Tiles 1, 3, 4, 5, 6, 8); drill-down to their track's source
GBs	Their assigned work area within their track; read-only on their own KPIs
Operations Director	Tiles 1, 2, 3 (production-impacting); aggregated views on others
IT Security	Tiles 3, 4, 5, 8 (security-relevant); aggregated on others
Legal/Compliance	Tile 8 (regulatory); aggregated on others
Other stakeholders	Aggregated executive summary only

All access logged; quarterly access audit by CISO team; data-access protocol (§3.5) governs the underlying query interface.

7.2.5 Visual Standards

- **Time axis:** last 12 weeks as default view; expandable to 24 weeks / 52 weeks

- **Color coding:** GREEN / AMBER / RED consistent across all tiles
- **Anonymisation:** no asset names, IP addresses, hostnames, or proprietary system identifiers on the dashboard
- **Refresh timestamp:** visible on every tile
- **Source link:** every metric has a clickable drill-down to the underlying anonymised data (per access control)
- **Mobile-friendly:** dashboard is responsive; CISO can view on tablet/phone

7.3 Bi-Weekly Briefings

The bi-weekly briefing is the CISO's primary synchronous touchpoint with the engagement. It is structured around the dashboard, not a slide deck.

7.3.1 Format

Element	Detail
Duration	30 minutes
Cadence	Every 2 weeks (10 working days)
Attendees	CISO (required), MBB (required); Track Leads (required if escalation open or their track is RED); Operations Director (optional, if line-impacting items)
Pre-read	Executive Dashboard snapshot (PDF, auto-generated 24h before)
Decision items	Pre-circulated by MBB 24h before (max 3 items)

7.3.2 Standing Agenda (30 minutes)

Time	Item	Owner
0–5 min	Dashboard walkthrough: Z-score, COPQ avoided, MTTD/MTTR, RPN trend, Kaizen activity, maturity score	MBB
5–10 min	RED/AMBER status review: any open escalations, open Kaizens > 5 BD, regression alerts	MBB
10–20 min	Decision items (max 3): budget, scope, risk appetite, vendor changes, personnel moves	CISO (decision); MBB (presentation)
20–25 min	Forward look: next 2 weeks, upcoming tollgates, scheduled drills, FMEA refresh	MBB
25–30 min	CISO questions and direction	CISO

7.3.3 Briefing Outputs

- **Meeting notes:** logged in engagement record within 24h
- **Action items:** tracked in dashboard action log; surfaced on Tile 5
- **CISO decisions:** logged with date and decision rationale
- **Escalations opened/closed:** logged in engagement anomaly log

7.3.4 Briefing Cadence Variations

- **Crisis mode (engagement-level RED):** bi-weekly becomes weekly; duration extended to 60 min
- **Stable mode (3+ consecutive GREEN briefings):** CISO may opt to move to monthly briefings; quarterly CISO touchpoint remains mandatory
- **CISO travel / unavailability:** designated CISO delegate (typically CISO's deputy) receives briefing; CISO briefed on return

7.4 Bi-Annual Audits

The bi-annual audit is the formal governance moment where the CISO assesses engagement health, signs off on continuation, and ratifies any re-scoping.

7.4.1 Format

Duration	2–4 hours (half-day for full audit)
Cadence	Every 6 months (2 per year)
Attendees	CISO (required), MBB (required), Operations Director (required), IT Security lead (required), Legal/Compliance (required for regulatory tile)
Pre-read	Audit pack (compiled by MBB): full dashboard review, control plan status, maturity score, COPQ protected value, audit findings, A3 close-out summary, FMEA delta, cross-site status (if applicable)

7.4.2 Standing Agenda (Half-Day)

Time	Item	Owner
0–30 min	Dashboard deep-dive: all 8 tiles, source data review, anomaly explanation	MBB
30–60 min	Control plan audit: all controls reviewed against §4.6 control plan; deviations explained; Poka-Yoke enforcement verified	MBB + Track Leads
60–90 min	Maturity score review: current level, sub-indicator scores, regression analysis, external validation (if applicable)	MBB + external assessor (if applicable)
90–120 min	COPQ & protected value: financial outcome review against §2.5 model; FMEA RPN reduction analysis; Tier 2/3 escalation log	MBB + Finance (if available)
120–150 min	Regulatory & compliance: NIS2, IEC 62443, OEM attestation status; audit findings; remediation evidence	MBB + Legal/Compliance
150–180 min	Forward look: next 6 months, upcoming threats, capability gaps, budget	MBB + Track Leads
180–240 min	CISO decisions: continuation, re-scoping, budget approval, risk appetite updates	CISO

7.4.3 Audit Outputs

- **Audit report:** signed by CISO; logged in engagement record
- **Continuation decision:** explicit go/no-go for next 6 months
- **Re-scope decision (if applicable):** documented with MBB commitment
- **Budget re-baseline (if applicable):** documented with executive committee referral if material
- **Action items:** tracked in dashboard action log

7.5 Annual Strategic Review

The annual review is the forward-looking strategic moment. It is the only governance event where the executive committee is involved.

7.5.1 Format

Element	Detail
Duration	4–8 hours (half-day to full-day)
Cadence	Annually
Attendees	CISO, MBB, executive committee (CEO / COO / CFO as relevant), Operations Director, IT Security lead, Legal/Compliance, external assessor (for maturity validation)
Pre-read	Strategic review pack: full year dashboard trend, all 5 audit reports, FMEA evolution, maturity score trend, COPQ realised, threat landscape evolution, regulatory direction

7.5.2 Standing Agenda (Full-Day)

Time	Item	Owner
0–60 min	Annual dashboard review: all 8 tiles, 52-week trend, year-over-year comparison	MBB
60–120 min	Maturity score external validation: third-party assessment; gap analysis; recommendations	External assessor
120–180 min	Strategic threat landscape: forward-looking threats, regulatory direction, technology shifts, OEM contractual changes	CISO + IT Security + external
180–240 min	Engagement re-scoping: does the current scope still match the threat? FMEA, control plan, AI agent scope, cross-site replication	MBB + CISO
240–300 min	Budget re-baseline: next-year budget based on revised scope, AI agent platform costs, external advisory	MBB + Finance + executive committee
300–360 min	Insurance & risk transfer review: does current coverage match the residual exposure?	Legal/Compliance + Finance + external broker
360–420 min	Cross-site replication planning: next 12 months' site onboarding; MBB capacity; cross-site audit exchange	MBB + CISO
420–480 min	Executive committee decisions:	Executive committee

	continuation, scope, budget, insurance, strategic direction	
--	---	--

7.5.3 Review Outputs

- **Strategic review report:** signed by CISO and executive committee chair
- **Next-year engagement plan:** scope, budget, milestones, risk appetite
- **Re-scope decision (if applicable):** documented; tollgates re-baselined
- **Insurance review decision:** documented; coverage update if needed
- **Maturity score external validation:** appended to next year's audit pack

7.6 What Section 7 Does Not Cover

Section 7 is the CISO governance cycle. The final substantive section covers:

- **§8 Constraints & Risks** — data-blind, confidentiality, vendor remote access, air-gap requirement, scope boundaries, engagement risks
- **Appendix A — CISO Elevator Pitch** — standalone, ~1 page
- **Appendix B — CISO Executive Dashboard Mockup** — standalone, visual mockup

Section 8 — Constraints & Risks

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: Synthesis of §§1–7 constraints and risk surfaces, cross-referenced with OSI whitepaper Layer 4 (Governance & Entropy Defence) principles

Emphasis: Explicit constraints (the hard boundaries), assumptions (what must be true for the engagement to succeed), engagement risks (what could go wrong), mitigations (how we address each), and residual risk acceptance (what remains after mitigations).

8.1 Constraints

The engagement operates within five categories of hard constraints. These cannot be relaxed by the MBB; only the CISO can adjust them, and only with explicit trade-offs.

8.1.1 Confidentiality & Data-Access Constraints

Constraint	Source	Cannot be relaxed because
Internal network configurations, IP addresses, hostnames, MAC addresses, raw network logs, vendor remote-access credentials, and proprietary system architectures are never accessible to Green Belts	Corporate confidentiality mandate; OT security best practice (IEC 62443)	A breach would expose the OT attack surface to an internal team of 19 engineers, materially increasing the blast radius of any single insider compromise
All GB data access flows through the CISO-controlled anonymisation pipeline	CISO mandate (§3.5)	Decoupling of operational data from engineering access is the binding trust boundary
Anonymisation pipeline is CISO-team-owned and operated; GBs cannot modify	CISO mandate (§3.5)	Pipeline integrity is the structural guarantee of the data-blind architecture
GB queries are logged and audited; quarterly third-party audit of the anonymisation pipeline	CISO mandate (§3.5)	Auditability is the only sustainable trust mechanism for the data-blind boundary
AI agents operate within the data-access protocol; no raw data access	CISO mandate; AI governance best practice	Agents cannot have privileges GBs do not have

Implication: Any MBB decision that would require raw data access (e.g. "let me see the actual firewall rules") must be escalated to the CISO for explicit override. The default posture is data-blind.

8.1.2 Resource Constraints

Constraint	Source	Cannot be relaxed because
------------	--------	---------------------------

Green Belt allocation: 10% per GB, 1.9 FTE effective team	CISO capacity allocation (\$5.7)	The 19 GBs have other primary duties; >10% allocation would require a separate CISO decision and engagement re-scoping
MBB: 1.0 FTE dedicated for 12 weeks; reduced allocation in continuation phase	MBB's consulting engagement terms	MBB is the methodology lead and sole presenter to CISO; under-allocation would compromise both
No additional headcount available for the 12-week push	CISO capacity decision	The 19 GBs are the maximum engineering capacity allocated; any expansion requires CISO decision
External advisory budget: modest; large tooling purchases require CISO sign-off	CISO procurement policy	Material expenditure requires separate business case; engagement operates within existing tooling where possible

Implication: The engagement's 1.9 FTE is the binding capacity constraint. Any scope addition must be matched with capacity addition (CISO decision).

8.1.3 Time Constraints

Constraint	Source	Cannot be relaxed because
12-week engagement with 5 fixed tollgates (G1–G5)	Engagement design	Tollgates are the CISO's decision points; extending the timeline changes the CISO cadence
5 risk-based decision points (DP-1 through DP-4) may extend timeline by 1–2 weeks per point	\$5.8 design	DPs are the safety valves for foreseeable risks; ad-hoc extension is not allowed
Cross-site replication timeline: 5 sites in 15 months post-G5	\$6.5 design	Replication is bounded by site MBB availability and the engagement MBB's mentorship capacity
Bi-weekly briefing cadence is fixed (every 2 weeks)	\$7.3 design	Cadence is the CISO's primary synchronous touchpoint; ad-hoc rescheduling signals crisis

Implication: The 12-week timeline is the binding commitment. If risks materialise, the DPs are the structured extension mechanism; ad-hoc extension is not the path.

8.1.4 Technical Constraints

Constraint	Source	Cannot be relaxed because
Air-gap requirement for safety-critical control systems (formation cycling, electrolyte injection)	\$4.5.3 Cyber Poka-Yoke	One-way data diodes on safety-critical paths prevent command injection; the only viable structural protection against RPN $\geq$ 320 safety modes
Cryptographic signing required for all process recipes (formation, coating, dosing, aging) and firmware updates	\$4.5.3 Poka-Yoke	Parameter integrity is the binding control for the 7 silent corruption modes in the FMEA
Vendor remote access must flow through authenticated broker with cryptographic handshake	\$4.5.3 Poka-Yoke; NIST SP 800-82	Vendor remote access is the #1 industrial ransomware vector (Dragos, Mandiant)
Legacy protocols (Telnet, FTP, SMBv1) must be decommissioned	\$4.5.2 Digital 5C Sort	Legacy protocols are unauthenticated or weakly authenticated; the FMEA root cause for several top-12 modes
No direct VPN access for vendors or non-engagement personnel	\$4.5.3 Poka-Yoke	Direct VPN bypasses all access controls; the only viable vendor model is brokered

Implication: The technical controls in §4.5 are not negotiable with vendors or internal teams. Any pushback escalates to the CISO.

8.1.5 Regulatory & Contractual Constraints

Constraint	Source	Cannot be relaxed because
NIS2 (EU) compliance: administrative fines up to €10M or 2% of global turnover	EU NIS2 Directive Art. 34	EU regulation; non-compliance is a board-level liability
IEC 62443 compliance for OT security	Industry standard; OEM contractual requirement	Standard practice; OEM attestation requires it
OEM cyber attestation requirements (VW, BMW, Stellantis, others)	OEM supplier contracts	Loss of attestation = loss of supply contract
GDPR (where personal data is in scope, e.g. operator credentials, audit logs)	EU GDPR Art. 83	Up to €20M or 4% of global turnover
EU Product Liability Directive 2024/2853 (safety-critical compromise)	EU PLD	Strict liability, uncapped

Implication: Regulatory non-compliance is a Tier 4 escalation. The engagement's Tile 8 (Regulatory & Compliance) on the Executive Dashboard is the primary tracking mechanism.

8.2 Assumptions

The engagement's plan is built on the following assumptions. If any of these is materially wrong, the engagement scope or timeline may need to be re-baselined (Tier 3 escalation to CISO).

#	Assumption	If wrong, impact
A1	The 19 Green Belts can be allocated at 10% weekly capacity for the 12-week push	Engagement re-scope; capacity extension to CISO
A2	The CISO's team can stand up the anonymisation pipeline within the first 3 weeks (G1)	Data lake deployment slips; DP-1 triggered; possible 2-week extension
A3	The current OT environment has a baseline capability of Z = 2.0–3.0 (industry typical)	If baseline is materially lower, the 12-week timeline may be insufficient; if materially higher, the timeline may compress
A4	Vendor remote-access landscape can be audited and brokered within 8 weeks	If vendors are uncooperative or technically incompatible, the FMEA root causes for #7, #8, #11 cannot be fully remediated
A5	The AI agent feasibility decision (build/buy/defer) can be made by end of Measure (W5)	If unclear, DP-3 triggered; Track C allocation adjustment
A6	The CISO is available for the 5 tollgates (G1–G5) on the scheduled dates	If CISO delegates, engagement quality depends on delegate authority
A7	The Operations Director is available for the G5 joint sign-off	If unavailable, G5 may slip; engagement handover delayed
A8	The engagement's 1.9 FTE is sufficient for the 12-week scope	If GBs report over-allocation, scope reduction required (CISO decision)

A9	Site MBBs are available for the cross-site replication phase (post-G5)	If site MBBs are unavailable, replication timeline extends
A10	The current regulatory environment (NIS2, IEC 62443, OEM attestation) is stable for the 12-week push	If regulatory change mid-engagement, scope re-baseline (Kaizen trigger #4)

8.3 Engagement Risks

Engagement risks are the foreseeable events that could derail the 12-week push. Each risk is scored on a 5×5 probability-impact matrix and has explicit mitigation, owner, and status.

8.3.1 Risk Scoring Matrix

Impact →	1 (Low)	2	3 (Med)	4	5 (High)
Prob ↓					
1 (Low)	1	2	3	4	5
2	2	4	6	8	10
3 (Med)	3	6	9	12	15
4	4	8	12	16	20
5 (High)	5	10	15	20	25
Threshold:	≥ 12 → Active mitigation required ≥ 16 → Escalation to CISO < 6 → Acceptable; monitor				

8.3.2 Risk Register (Top 8 Engagement Risks — Sharpest Register)

#	Risk	Prob	Impact	Score	Mitigation	Owner	Status
1	Data lake deployment slips past W4 (Track B critical path)	3	5	15	Track B gets 7 GBs (largest team); MBB direct oversight; DP-1 (W4) triggers if blocked; engagement pauses if data lake not operational by G2	MBB + Track B Lead	Active
2	GB capacity conflict at peak load (W6–W10)	4	4	16	MBB monitors GB load weekly; >12% per GB triggers Tier 2 escalation and scope re-baseline; peak load is structural, not discretionary	MBB	Active

3	Vendor remote-access resistance (vendors refuse broker)	3	4	12	CISO escalation for uncooperative vendors; CISO has contractual authority; alternative: restrict vendor access entirely (cutover)	MBB + CISO	Active
4	AI agent build/buy decision blocked	3	4	12	DP-3 (W5) trigger; fall back to "build" with external AI engineering support; timeline +2 weeks	MBB + Track C Lead	Active
5	Real cyber event during engagement (GB capacity diverted to IR)	2	5	10	IR playbook pre-positioned; GBs on-call rotation; MBB reassigns capacity; engagement timeline may extend; CISO briefed on any diversion	MBB + IT Security	Monitor
6	Engagement scope creep (additional failure modes or requirements mid-engagement)	3	3	9	Tier 3 escalation; explicit trade-off: scope addition requires capacity addition or timeline extension; CISO decision	CISO + MBB	Monitor
7	CISO sign-off delays at tollgates (CISO travel/unavailability)	2	4	8	CISO delegate authorised; pre-tollgate review 24h before; MBB escalation if delegate unavailable	MBB	Monitor
8	Regulatory / contractual change mid-engagement (NIS2 amendment, OEM attestation update)	2	4	8	Kaizen trigger #4; MBB + Legal assess within 5 BD; control plan update; CISO briefing	MBB + Legal	Monitor

Active-mitigation risks (score ≥ 12): #1, #2, #3, #4

Acceptable / monitor risks (score < 12): #5, #6, #7, #8

Risks dropped from the original 12-risk draft (now covered by other mechanisms):

- ~~#8 Cross-site MBB unavailability~~ — post-G5 only; covered by §6.5 site MBB certification pipeline
- ~~#10 Key GB departure~~ — covered by cross-training in Standard Work + Kaizen trigger #6
- ~~#11 OEM contractual change~~ — merged into #8 (regulatory/contractual change)
- ~~#12 Structural change mid-engagement~~ — covered by Kaizen triggers #11–#13 with Tier 3 escalation

8.3.3 Risk Categories

The risk register is organised by category for executive visibility:

Category	Risks	Highest score
Schedule risks	#1 (data lake), #7 (CISO delays)	15
Resource risks	#2 (GB capacity)	16
Technical risks	#3 (vendor resistance), #4 (AI decision)	12
Stakeholder risks	#6 (scope creep), #7 (CISO)	9
External risks	#5 (real cyber event), #8 (regulatory)	10

The highest single risk is **#2 (GB capacity conflict at peak load, score 16)** — this is the only risk that crosses the escalation threshold and warrants explicit CISO awareness at G1.

8.4 Residual Risk Acceptance

After all mitigations are applied, the engagement accepts the following residual risks. These are explicitly acknowledged by the CISO at G1 and tracked on Tile 4 (Risk Mitigation) of the Executive Dashboard.

Residual Risk	Acceptance Rationale
Silent corruption (SC) modes may produce a recall event between FMEA refreshes	FMEA refreshed quarterly; AI agents provide 24/7 monitoring; control plan limits dwell time; insurance covers recall cost
IP exfiltration (E_ip) cannot be fully prevented — only detected and contained	NIST/industry consensus; mitigations reduce probability but cannot eliminate; insurance + Legal review
Safety tail risk (E_safety) is bounded by Severity = 10 in FMEA but cannot be insured to full exposure	Structural controls (Poka-Yoke, air-gap) reduce probability; unbounded tail is structural reality
Vendor remote-access may still be exploited if vendor endpoint is compromised	Brokered access + session recording + cryptographic handshake limit blast radius; quarterly vendor risk review
Regulatory environment may change mid-engagement	Kaizen trigger #4; MBB + Legal monitoring; control plan adaptable
Cross-site replication may not achieve Level 5 maturity by month 18	Maturity model is aspirational; Level 4 is the contractual target
GB over-allocation may require scope reduction at peak load	MBB monitors; Tier 2 escalation; CISO trade-off decision

Residual risk acceptance is a CISO decision at G1. The CISO may amend the acceptance list at any subsequent tollgate or bi-annual audit.

8.5 Engagement Entropy Defence

Following the OSI whitepaper's Layer 4 principles, the engagement embeds entropy defence mechanisms to prevent the engagement itself from drifting:

- 20. **Tollgate discipline** — no phase advances without CISO sign-off (G1–G5)
- 21. **Bi-weekly briefing** — CISO continuously informed; entropy surfaced early
- 22. **Bi-annual audit** — formal review every 6 months; control plan validated
- 23. **Maturity scoring** — quarterly self-assessment; regression triggers escalation
- 24. **Standard Work compliance** — 100% target; non-compliance escalates
- 25. **Kaizen triggers** — 13 conditions; A3 within 5 BD; structural changes escalate to Tier 3
- 26. **Risk register** — quarterly refresh; active risks actively mitigated
- 27. **MBB presence** — sole presenter to CISO; methodology integrity owned
- 28. **Documentation discipline** — every tollgate, audit, Kaizen, FMEA refresh is documented
- 29. **Cross-site replication** — site MBB certification; cross-site audit exchange; enterprise benchmark

Entropy defence principle: The engagement's governance is the structural protection against project degradation. The OSI whitepaper's Layer 4 logic applies to the engagement itself, not just to the OT environment.

8.6 What Section 8 Does Not Cover

Section 8 is the constraints and risks framework. The final components of the Phase 1 (Define) deliverable are:

- **Appendix A — CISO Elevator Pitch** — standalone, ~1 page, the verbal opener for the CISO meeting
- **Appendix B — CISO Executive Dashboard Mockup** — standalone, visual mockup of Tile 1–8 structure
- **Final compilation** — all 8 sections + 2 appendices compiled to Cyber-Resilience-Project-Charter.docx once all components are approved

Appendix A — CISO Elevator Pitch

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: Polished from the pitch in `context/00-original-input.md` §CISO Elevator Pitch, expanded into three audience-tailored variants

Emphasis: Three pain points (silent corruption, IP exfiltration, COPQ) lead the CISO and Board variants, intertwined with safety, IP, and ROI/COPQ. The 30-Second variant compresses the same architecture into a single spoken paragraph.

A.1 CISO Opening (the primary, for the G1 meeting)

Context: The verbal opener for the CISO's first tollgate review (G1, end of Week 3). Spoken in the pre-tollgate review and the G1 meeting itself. ~3 minutes spoken. Frames the engagement as the structural answer to the three pain points the CISO already carries.

The three pain points — what the CISO already knows but cannot fix with current posture

1. Silent corruption is a recall waiting to happen, not a downtime event.

Seven of our top 12 FMEA failure modes are silent corruption — process parameters altered, no halt, cells pass inspection, fail in field. The highest-RPN mode is aging cycle manipulation in formation: RPN 540, Severity 10. Probability-adjusted annual exposure: \$5M–\$50M per department. This is the failure class that produces recalls, warranty extensions, and OEM contractual breach — and the failure class our current IT security perimeter cannot detect, because there is no halt to alert on. The original OSI entropy framework did not have to carry this exposure. The cyber engagement does.

2. IP exfiltration is permanent loss, not a recoverable incident.

Battery chemistry IP is valued at \$100M–\$1B+ per platform — formation recipes, electrolyte chemistry, dopant systems, cell designs. The probability-adjusted annual exposure is \$10M–\$100M per department. Once exfiltrated, the IP is gone — it cannot be recovered, and most of it cannot be insured. State-aligned APTs target this IP class specifically. The original OSI whitepaper's exposure band was \$6M–\$16M per department; the cyber engagement's exposure band is \$20M–\$180M+ per department, driven by IP and silent corruption.

3. Every minute of MTTR above target is \$4K–\$11.5K of direct loss, on every line, every event.

The blended COPQ for a high-volume cell line is \$4,000–\$11,500 per minute — \$240K–\$690K per hour. The per-incident direct cost for a major event is \$30M–\$100M+. Every minute of MTTR breach is direct cost, compounded across the 5-site enterprise. The 5-site protected value at conservative capture (M=25%) is \$25M–\$225M+ per year. Every minute we delay the engagement is exposure we have already decided to accept.

The structural answer — what this engagement delivers

This is not an IT security initiative. It is a **Lean Six Sigma process-defect programme** applied to cyber-induced downtime, executed by 19 Green Belts across 12 weeks under DMAIC discipline, with capability indices rolled up to **Z ≥ 6.0** (theoretical Six Sigma, 0.002 DPMO short-term / 3.4 DPMO with the 1.5σ long-term drift shift). The methodology is data-blind (your team's anonymisation pipeline is the trust boundary), the failure modes are statistically derived (FMEA with S×O×D scoring, 7 of 12 modes at Severity = 10), and the controls are structural rather than procedural (Cyber Poka-Yoke, SMED recovery rigs, AI-augmented Layer 3, cryptographic recipe signing).

The engagement is not asking you to accept more risk. It is asking you to make the existing risk **statistically visible, structurally contained, and continuously governed** — through the Executive Dashboard (8 tiles, real-time Z-score, COPQ protected, MTTR/MTTD, FMEA RPN, Kaizen activity, maturity score, regulatory compliance), the bi-weekly briefings, the bi-annual audits, and the annual strategic review. Your risk appetite sets the target; the engagement delivers the capability to hit it.

The ask — what the CISO signs off on at G1

You are the sole signatory on G1. The ask is:

- 30. **Approve the charter** — §§1–8 of this document, scope, team, 12-week timeline, 5 tollgates
- 31. **Approve the data-access protocol** — your team's anonymisation pipeline; GBs query only post-anonymisation outputs; quarterly third-party audit
- 32. **Approve the 4 active-mitigation risks** — the 4 risks at score ≥ 12, with explicit mitigations
- 33. **Approve the 7 residual risks** — the risks the engagement accepts, with explicit acknowledgement

The 12-week engagement delivers **Z ≥ 6.0 capability** (theoretical Six Sigma, 0.002 DPMO short-term / 3.4 DPMO with the 1.5σ long-term shift), **≥ 80% RPN reduction** across the top 10 cyber failure modes, and **≥ 99% patch compliance** within maintenance windows. The 5-site enterprise protected value is \$25M–\$225M+ per year at conservative capture. The cost of no-action compounds annually; the cost of action is 1.9 FTE for 12 weeks.

This engagement makes your "zero cyber-induced downtime" mandate statistically verifiable, not aspirational.

A.2 Board Pitch (for executive committee, Annual Strategic Review)

Context: The pitch for executive committee members (CEO, COO, CFO) and the Annual Strategic Review (\$7.5). ~5 minutes spoken. Frames the engagement as enterprise risk mitigation, not operational initiative. Same three pain points, board-level framing.

The three pain points — at enterprise scale

1. Silent corruption is the failure class that produces recalls, field failures, and OEM contractual breach — and the only one that traditional cybersecurity cannot see.

In our top 12 FMEA modes, 7 are silent corruption (parameter tampering, no halt, in-line inspection passes, field failure). The highest RPN is 540 (formation aging cycle manipulation); the median for the SC class is 405. Each SC event produces a recall cost of \$10M–\$200M+ — the recall is the visible event, the IP and OEM contractual loss is the structural tail. Probability-adjusted annual exposure: \$5M–\$50M per department, \$25M–\$250M+ at the 5-site enterprise. This is the failure class the OSI entropy framework could not have carried; the cyber engagement is the structural answer.

2. IP exfiltration is the largest single exposure class and the most uninsurable.

Battery chemistry IP (formation recipes, electrolyte formulations, dopant systems) is valued at \$100M–\$1B+ per platform. The 5-site enterprise exposure is \$50M–\$500M+ per year at conservative capture, driven by state-aligned APT targeting of advanced cell chemistry. Once exfiltrated, the IP is permanent — recovery probability is structurally low, insurance coverage is structurally inadequate. This is the existential tail for any Tier-1 cell supplier; it is also the dominant motivation for state-aligned targeting. The engagement's IP-protection scope is the binding control.

3. COPQ is the operating cost the CISO and CFO both see on the same dashboard.

The blended COPQ for a high-volume cell line is \$4,000–\$11,500 per minute of cyber-induced downtime — \$240K–\$690K per hour. Per-incident direct cost is \$30M–\$100M+ for a major event. The 5-site enterprise protected value at M=25% is \$25M–\$225M+ per year; at M=50%, \$50M–\$450M+ per year. The 12-week engagement costs 1.9 FTE + modest external advisory; the ROI multiple is 5–10× even at conservative capture. **The cost of action is bounded; the cost of no-action compounds annually.**

The structural answer — at enterprise scale

This is a 12-week process-defect programme, executed by 19 Green Belts under DMAIC, that delivers:

- **$Z \geq 6.0$ capability** for cyber-induced downtime (theoretical Six Sigma, 0.002 DPMO short-term / 3.4 DPMO with 1.5 σ long-term shift)
- **$\geq 80\%$ RPN reduction** across the top 10 cyber failure modes (Cyber-FMEA)
- **100% audit-pass** for NIS2, IEC 62443, and OEM cyber attestation
- **5-site enterprise protected value** of \$25M–\$225M+ per year (conservative)
- **Continuous governance** via the Executive Dashboard, bi-weekly briefings, bi-annual audits, and annual strategic review

The engagement embeds structural controls (Cyber Poka-Yoke, SMED recovery rigs, AI-augmented Layer 3, cryptographic recipe signing) that make certain failure modes **structurally impossible** — not just procedurally discouraged. The continuation phase (Green Belt Standard Work, 13 Kaizen triggers, maturity scoring, cross-site replication) prevents the engagement from fading into entropy relapse.

The ask — at enterprise scale

The executive committee is asked to:

34. **Back the engagement at the policy level** — set "zero cyber-induced downtime" as a board-level operational target, with the **$Z \geq 6.0$ capability** (theoretical Six Sigma) as the measurable expression
35. **Approve the budget envelope** — 1.9 FTE GB allocation + modest external advisory; total all-in cost is a fraction of the 5-site enterprise protected value
36. **Approve the cross-site replication plan** — Site 2 through Site 5 in 15 months post-G5; enterprise benchmark at month 18
37. **Ratify the data-access protocol** — CISO-owned anonymisation pipeline; data-blind trust boundary

The engagement's IP and safety scope makes it a **strategic risk mitigation programme**, not a security programme. The board's role is to set the risk appetite, ratify the budget, and ratify the cross-site rollout. The CISO runs the engagement; the MBB executes the methodology; the 19 Green Belts deliver the controls.

This engagement converts "zero cyber-induced downtime" from a board aspiration into a board-level operating discipline.

A.3 30-Second Elevator (for impromptu conversations)

Context: The compressed pitch for corridor conversations, OEM customer meetings, peer-CISO gatherings, and any other impromptu moment. ~30 seconds spoken (3 sentences, ~75 words).

> **Silent corruption is the failure class that produces recalls and field failures — 7 of our top 12 cyber FMEA modes, Severity 10, no halt to detect them. Battery chemistry IP is the largest single exposure class at \$100M–\$1B+ per platform, and it's the most uninsurable. We're running a 12-week Lean Six Sigma programme with 19 Green Belts to deliver $Z \geq 6.0$ capability (theoretical Six Sigma), \$25M–\$225M+ per year protected value at the 5-site enterprise, and 100% audit-pass for NIS2 and OEM attestation — the cost of action is 1.9 FTE; the cost of no-action compounds annually.**

Variant — for OEM customer conversations (regulatory + contractual emphasis)

> **NIS2 and OEM cyber attestation are now table-stakes; the 2024–2027 enforcement window is the binding constraint for cell suppliers. We've built a Lean Six Sigma programme that delivers $Z \geq 6.0$ capability (theoretical Six Sigma), 100% audit-pass, and continuous governance via an Executive**

Dashboard that the CISO and OEM can both see. The methodology is data-blind (your confidentiality mandate is protected), the failure modes are statistically derived, and the cross-site replication is built in — it's the operating discipline that turns attestation from a compliance exercise into a capability.

Variant — for IT Security peer conversations (technical emphasis)

> We're running a 19-Green-Belt DMAIC programme on cyber-induced downtime in EV cell manufacturing — same LSS MBB framework I used for the OSI entropy whitepaper, but the cyber failure class is structurally different. The top 12 FMEA modes are dominated by silent corruption (parameter tampering, no halt, RPN up to 540), and the AI-augmented Layer 3 is what makes the $Z \geq 6.0$ (theoretical Six Sigma) target achievable. The 4 AI agents (SOC Triage, OT Anomaly Detection, IR Automation, Threat Intel Correlation) operate within the data-access protocol; CISO retains kill-switch. It's a defensible MBB structure with the methodology rigour that most OT cyber programmes lack.

Appendix B — CISO Executive Dashboard Mockup

Section status: Draft for review

Reviewer: Olivia Key (MBB)

Source: Compiled from §7.2 Executive Dashboard structure. Text-based mockup for the charter; a separate interactive HTML mockup is provided as a standalone deliverable.

Emphasis: Visual reference for the CISO's continuous visibility tool. Sample data is illustrative (Week 12 G5 state, anonymised, no real asset identifiers). The HTML mockup is the interactive version; this is the static reference.

B.1 Dashboard Overview (2×4 Tile Grid)

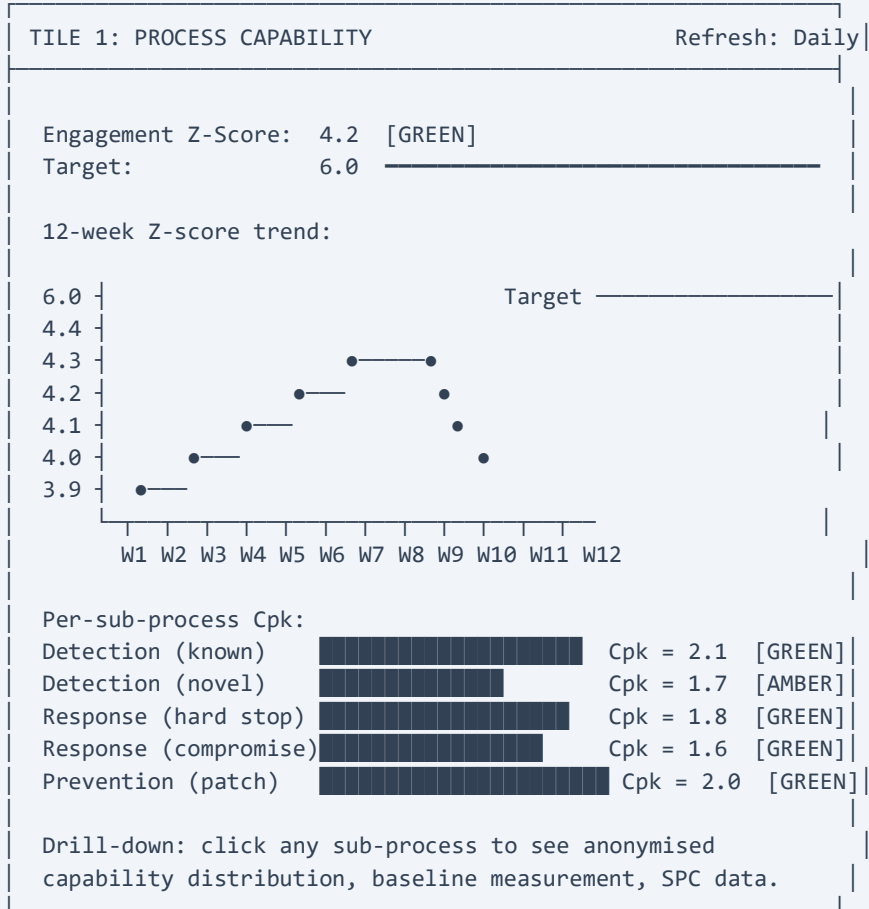
The Executive Dashboard is structured as a 2×4 grid of 8 tiles, mapped to the engagement's key metrics. Each tile has its own refresh cadence, alert threshold, and access control.

EV CELL CYBER RESILIENCE — EXECUTIVE DASHBOARD Anonymised Z-Score: 4.2 Last Refresh: 2026-09-02 09:00 UTC Status: GREEN	
TILE 1: PROCESS CAPABILITY [Z-Score trend]	TILE 2: FINANCIAL EXPOSURE [COPQ avoided YTD / Protected value realised / E_cyber band]
TILE 3: VELOCITY METRICS [MTTD/MTTR trend + drill results + drill targets]	TILE 4: RISK MITIGATION [FMEA RPN trend by mode / patch compliance / vendor]
TILE 5: KAIZEN ACTIVITY [Open/closed Kaizens / trigger frequency / A3 close-out time]	TILE 6: MATURITY SCORE [Current level + sub-indicator scores + trend + alerts]
TILE 7: CROSS-SITE STATUS [Per-site maturity / Z-score / replication progress]	TILE 8: REGULATORY & COMPLIANCE [NIS2 / IEC 62443 / OEM / audit findings]

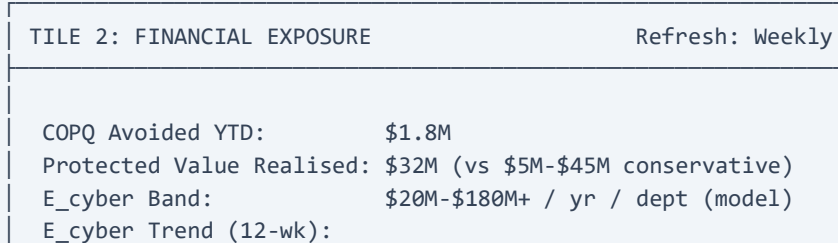
Status indicator: Dashboard-level status (GREEN/AMBER/RED) is the worst-status of any tile, with the overall engagement Z-score as the headline number. A single RED tile flips the dashboard to RED.

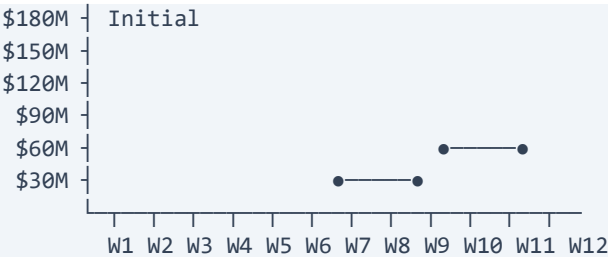
B.2 Tile Mockups with Sample Data (Illustrative, G5 State)

B.2.1 Tile 1 — Process Capability



B.2.2 Tile 2 — Financial Exposure





Per-event cost avoided breakdown:

- Downtime avoidance: \$8M
- Silent corruption avoided: \$14M
- IP protection: \$6M
- Regulatory fines avoided: \$4M

Note: E_cyber band widens over time as OEM attestation enforcement tightens (VW/BMW/Stellantis 2025-2027).

B.2.3 Tile 3 — Velocity Metrics

TILE 3: VELOCITY METRICS

Refresh: Daily

Detection (MTTD):

Known signatures: 4.2 min [Target ≤ 5 min, GREEN]

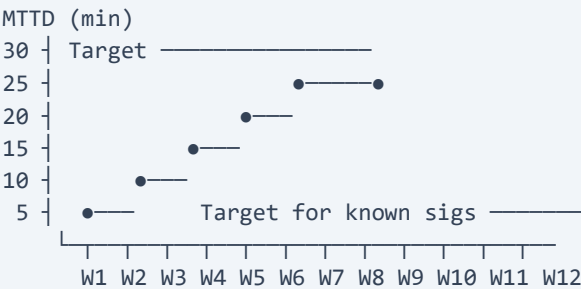
Novel OT anomalies: 28 min [Target ≤ 30 min, GREEN]

Response (MTTR):

Hard stop: 3.5 hours [Target ≤ 4 hours, GREEN]

OT compromise: 22 hours [Target ≤ 24 hours, GREEN]

12-week MTTD/MTTR trend:



Drill results (last 3 monthly drills):

Drill 1: Hard stop MTTR achieved in 3.2h [PASS]

Drill 2: Novel anomaly MTTD achieved in 26m [PASS]

Drill 3: Hard stop MTTR achieved in 3.7h [PASS]

AI agent status:

SOC Triage Agent: OPERATIONAL | last action: 2h ago

OT Anomaly Agent: OPERATIONAL | last action: 18m ago

IR Automation Agent: OPERATIONAL | last action: 4d ago

Threat Intel Agent: OPERATIONAL	last action: 1h ago
---------------------------------	---------------------

B.2.4 Tile 4 — Risk Mitigation

TILE 4: RISK MITIGATION

Refresh: Daily

Top 5 FMEA RPN trend (12-week):

RPN

600

540

490

480

450

450

(Formation aging)

(Coating thickness)

(Slurry sensor)

(Grading capacity test)

(Coating vision)

W1

W2

W3

W4

W5

W6

W7

W8

W9

W10

W11

W12

RPN reduction (post-engagement vs pre-engagement):

Top 10 modes: 52% reduction [Target ≥ 80% (Six Sigma), AMBER]

Patch compliance: 96.2% [Target ≥ 99% (Six Sigma), AMBER]

Vendor access compliance: 100% [Target = 100%, GREEN]

FMEA last refresh: 2026-08-15 [Quarterly, GREEN]

Open audit findings: 0 [Target = 0, GREEN]

B.2.5 Tile 5 — Kaizen Activity

TILE 5: KAIZEN ACTIVITY

Refresh: Daily

Open Kaizens: 3

Closed YTD: 12

A3 close-out time (median): 4.2 BD [Target ≤ 5 BD, GREEN]

Trigger frequency (YTD):

SPC UCL breach: 4

MTTR breach in drill: 1

New asset ingress: 3

Regulatory change: 1

Industry peer event: 2

Personnel change: 0

Audit finding: 0

AI agent drift: 0

Process change: 0

Tooling change: 1

Supply chain: 0

M&A: 0

IP licensing:0

Open Kaizens (top 3 by age):

1. SPC UCL breach – formation latency spike (2.1 BD)

2. New asset ingress – new BMS firmware (1.8 BD)

3. Industry peer event – competitor breach (0.9 BD)

B.2.6 Tile 6 — Maturity Score

TILE 6: MATURITY SCORERefresh: Quarterly

Current Level: 4 – Quantitatively Managed [GREEN]

Target: 4 (sustained) → 5 (Optimising)

Sub-indicator scores (0-2 each):

Standard Work:2/2

FMEA refresh:2/2

SPC active:2/2

Cpk measured:2/2

AI agents operational:2/2

Poka-Yoke enforced:1/2

Kaizen cycle:2/2

Cross-site audit:0/2 (pending Site 2 onboarding)

Total:13/16 = 81%

Trend: ↗ (improving from Level 3 at G5)

External validation: 2026-Q3 (next: 2027-Q3)

Regression alerts: None

B.2.7 Tile 7 — Cross-Site Status

TILE 7: CROSS-SITE STATUSRefresh: Monthly

Site	Status	Maturity	Z-Score	Replication Phase
Site 1	[ACTIVE]	Level 4	4.2	G5 complete
Site 2	[ONBOARDING]	Level 2	2.8	Wk 8 of 12
Site 3	[PENDING]	n/a	n/a	Not started
Site 4	[PENDING]	n/a	n/a	Not started
Site 5	[PENDING]	n/a	n/a	Not started

Replication timeline:

Site 2: M4-6 [In progress]

Site 3: M7-9

Site 4: M10-12

Site 5: M13-15

Enterprise benchmark: M18+

Knowledge transfer cadence: Weekly cross-site sync

Cross-site audit exchange: Quarterly

B.2.8 Tile 8 — Regulatory & Compliance

TILE 8: REGULATORY & COMPLIANCE		Refresh: Monthly
NIS2 (EU):	✓ COMPLIANT	[Last audit: 2026-Q2]
IEC 62443:	✓ COMPLIANT	[Last audit: 2026-Q2]
OEM cyber attestation:	✓ COMPLIANT	[Last attest: 2026-Q2] (VW, BMW, Stellantis, others)
GDPR:	✓ COMPLIANT	[Last review: 2026-Q1]
EU PLD 2024/2853:	✓ STRUCTURAL CONTROLS	OPERATIONAL
Open audit findings:	0	
Pending regulatory changes:	1 (NIS2 amendment Q4-2026)	
OEM attestation renewals:	2 due in next 90 days	
Recent compliance activity:		
2026-08-12	OEM attestation renewed (BMW)	
2026-07-28	NIS2 internal audit completed	
2026-07-15	IEC 62443 surveillance audit passed	

B.3 Color Coding & Alert System

The dashboard uses a 3-tier color coding system, consistent across all tiles:

Color	Status	Definition	CISO Notification
 GREEN	On target	All metrics within engagement target; no open issues	Standard cadence (bi-weekly briefing)
 AMBER	Drift	One or more sub-process below target; open Kaizen > 5 BD; FMEA refresh overdue; or other warning signals	Bi-weekly briefing escalates; MBB + Track Lead investigate within 48h
 RED	Critical	Engagement Z-score < 4.0; Tier 2/3 escalation open; structural change trigger (M&A / IP licensing / supply chain); or safety event	CISO notified within 4h; emergency briefing within 24h; engagement re-scope possible

Dashboard-level status: Worst-status of any tile, with engagement Z-score as the headline number. A single RED tile flips the dashboard to RED.

B.4 Interactive Features

The dashboard is interactive, with the following features:

Feature	Description
Drill-down	Click any tile metric to view anonymised source data (per access control)
Time range	Toggle between 12-week, 24-week, 52-week views
Export	CISO and MBB can export tile data as PDF or CSV; logged in audit trail
Annotations	MBB and Track Leads can add annotations to metrics (e.g. "W7 spike due to planned maintenance")
Alerts	Configurable per-tile alerts via email or push notification; RED status triggers immediate alert
Mobile	Responsive design; CISO can view on tablet/phone with same access controls
Audit log	Every dashboard view, drill-down, export, annotation is logged; quarterly CISO review

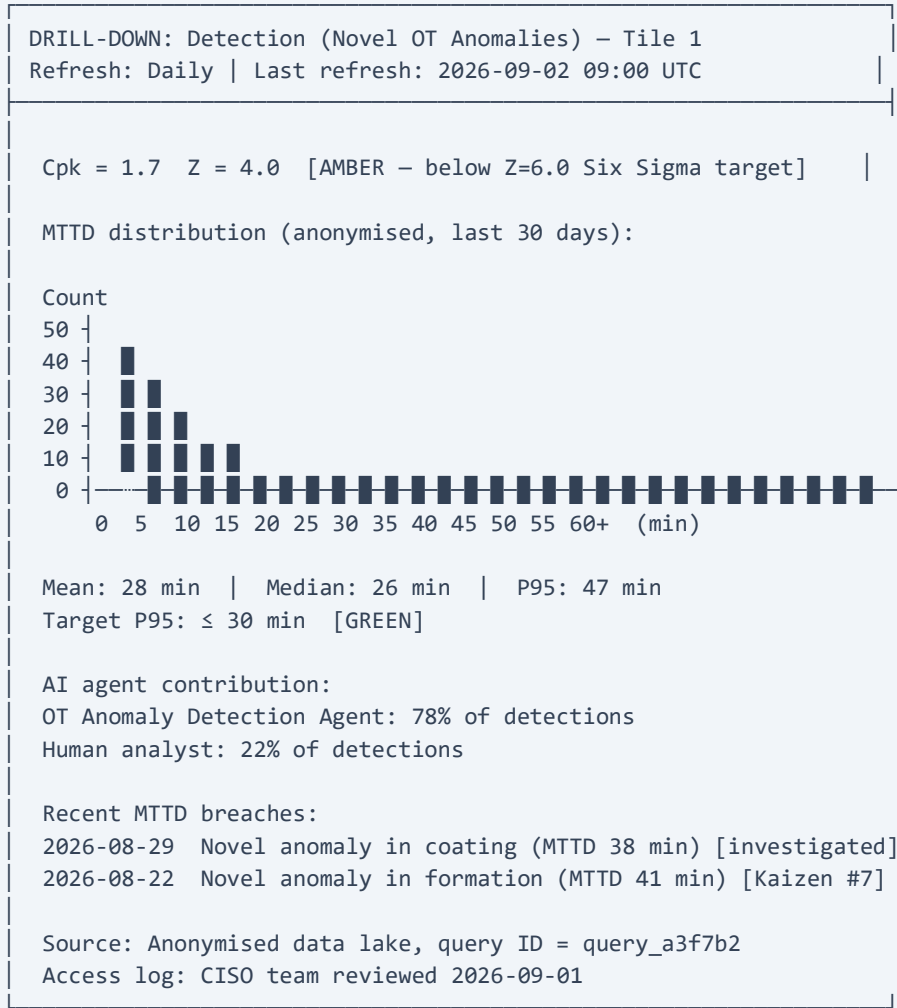
B.5 Mobile View (CISO Tablet/Phone)

The dashboard is mobile-responsive. On tablet/phone, the 2x4 grid collapses to a single-column scroll:

EV CELL CYBER DASHBOARD Z-Score: 4.2 [GREEN]
TILE 1: Process Capability [Z-Score trend]
TILE 2: Financial Exposure [COPQ avoided]
TILE 3: Velocity Metrics [MTTD/MTTR]
TILE 4: Risk Mitigation [RPN trend]
TILE 5: Kaizen Activity [Open/closed]
TILE 6: Maturity Score [Level 4]
TILE 7: Cross-Site Status [Site 1 G5; Site 2 M4-6]
TILE 8: Regulatory [All compliant]

B.6 Sample Drill-Down: Tile 1 → Sub-Process Capability

Clicking on "Detection (novel)" in Tile 1 opens the drill-down view:



The drill-down is fully anonymised per the data-access protocol (§3.5). Source data is accessible only via the CISO's anonymised data lake; the query ID is logged for audit.

B.7 What Appendix B Does Not Cover

Appendix B is the static reference for the Executive Dashboard. The interactive HTML mockup is provided as a **separate deliverable** (see [deliverables/](#) folder) for the CISO meeting presentation. The final compiled charter includes both this static mockup and a link/reference to the interactive HTML version.